Alma Mater Studiorum · Università di Bologna

SCUOLA DI SCIENZE

Corso di Laurea in Informatica per il Management

Implicazioni organizzative della Direttiva NIS2: il supporto degli standard internazionali e il ruolo strategico del CISO nell'attuazione della normativa

Relatore:
Chiar.mo Prof.
Edoardo Mollona

Presentata da:
Francesco Maria Fuligni

Sessione II
Anno Accademico 2024/2025

Il futuro è tutto davanti a te, carico di sorprese e di promesse.

Sei all'alba della Vita!

– *Don Andrea Scognamiglio*

Indice

1 Introduzione **1**

1.1 Contesto 1

1.2 Minacce alla sicurezza informatica 2

1.2.1 Europa 2

1.2.2 Italia 3

1.3 Standard internazionali e direttive europee 5

1.4 Cosa cambia per le aziende 6

1.5 Obiettivo 7

1.6 Metodologia 8

2 Implicazioni organizzative della Direttiva NIS2 **11**

2.1 Confronto tra le Direttive NIS e NIS2 11

2.2 Misure principali della Direttiva NIS2 12

2.2.1 Ambiti e soggetti coinvolti 12

2.2.2 Gestione del rischio 13

2.2.3 Misure di cybersicurezza 15

2.2.4 Obblighi di notifica 16

2.2.5 Governance aziendale e responsabilità 16

2.3 Direttiva NIS2 in Italia: ACN e CSIRT Italia 17

2.4 Implicazioni organizzative della Direttiva NIS2 18

2.4.1 Governance e responsabilità nella gestione del rischio 19

2.4.2 Misure di sicurezza 20

2.4.3 Sicurezza della supply chain 21

2.4.4 Notifica degli incidenti 23

2.4.5 Formazione e cultura della sicurezza informatica 24

2.4.6 Sfide per le organizzazioni 24

3 Standard internazionali e framework per la cybersicurezza 27

3.1 Standard ISO/IEC 27001:2022 27

3.1.1 Scopi e struttura dello standard 27

3.1.2 Misure di gestione del rischio informatico 28

3.1.3 Controlli di sicurezza: Annex A 29

3.1.4 Implicazioni organizzative della certificazione ISO 27001 30

3.2 NIST Cybersecurity Framework 2.0 32

3.2.1 Scopi e struttura del framework 32

3.2.2 Approccio basato sul rischio e implementazione 34

3.2.3 Implicazioni organizzative dell'adozione del NIST CSF 2.0 36

4 Analisi comparativa tra standard internazionali per l'adempimento di NIS2 39

4.1 Introduzione al confronto 39

4.1.1 ISO 27001, NIST CSF 2.0 e NIS2 39

4.1.2 Framework di cybersicurezza nazionali 40

4.1.3 Tabella comparativa 41

4.2 Allineamento di ISO 27001 con NIS2 42

4.2.1 Convergenze 42

4.2.2 Divergenze 43

4.2.3 Ruolo nell'implementazione di NIS2 45

4.3 Allineamento del NIST CSF 2.0 con NIS2 46

4.3.1 Convergenze 46

4.3.2 Divergenze 48

4.3.3 Ruolo nell'implementazione di NIS2 49

5 Tabella di comparazione tra NIS2, ISO/IEC 27001:2022 e NIST CSF 2.0 51

5.1 Politica per la sicurezza delle reti e dei sistemi informativi 52

5.2 Politica di gestione del rischio 52

5.3 Gestione degli incidenti 53

5.4 Continuità operativa e gestione delle crisi 54

5.5 Sicurezza della catena di fornitura 54
5.6 Sicurezza nell'acquisizione, nello sviluppo e nella manutenzione di sistemi e servizi ICT 55
5.7 Politiche e procedure per valutare l'efficacia delle misure di gestione del rischio di cybersicurezza 56
5.8 Buone pratiche di igiene informatica e formazione sulla sicurezza 56
5.9 Crittografia 57
5.10 Sicurezza delle risorse umane 57
5.11 Controllo degli accessi 58
5.12 Gestione degli asset 58
5.13 Sicurezza fisica e ambientale 59

6 La figura del CISO nell'adempimento della Direttiva NIS2 61
6.1 CISO: compiti ed evoluzione della figura 61
6.1.1 Compiti del CISO 61
6.1.2 Evoluzione del ruolo del CISO 64
6.2 Con chi interagisce il CISO 65
6.2.1 Dialogo con gli organi di gestione 66
6.3 Gestione del rischio 67
6.4 Adempimento della Direttiva NIS2 nelle organizzazioni 68
6.4.1 Ruolo e responsabilità del CISO 68
6.4.2 Delega di responsabilità 70
6.5 Ruolo degli standard secondo i CISO 71

7 Conclusioni 73
7.1 Implicazioni organizzative della Direttiva NIS2 73
7.1.1 Responsabilità nella gestione del rischio 73
7.1.2 Misure di sicurezza e sicurezza della supply chain 74
7.1.3 Notifica degli incidenti 75
7.1.4 Sfide per le organizzazioni 75
7.2 Ruolo degli standard internazionali nell'adempimento della Direttiva NIS2 77
7.2.1 ISO/IEC 27001:2022 a confronto con NIS2 77
7.2.2 NIST CSF 2.0 a confronto con NIS2 78

7.2.3 Ruolo degli standard internazionali nell'adempimento di NIS2 . . . 79
7.3 Ruolo del CISO nell'adempimento della Direttiva NIS2 81
7.3.1 Evoluzione della figura del CISO 81
7.3.2 Responsabilità e gestione del rischio 82
7.4 Considerazioni generali e visione prospettica 82
7.4.1 Impatto futuro di NIS2 82
7.4.2 Intelligenza artificiale e sicurezza informatica 83

Bibliografia **85**

Sitografia **89**

Interviste **91**

Ringraziamenti **93**

Elenco delle figure

1.1 Ripartizione degli incidenti analizzati per tipologia di minaccia[1] 3
1.2 Settori colpiti per numero di incidenti[2] 4
1.3 Crescita percentuale in Italia a confronto con il dato globale[3] 5

3.1 Funzioni del framework NIST CSF 2.0[4] 33

6.1 Flusso di implementazione della direttiva NIS2[5] 72

7.1 Flusso di implementazione NIS2 senza l'utilizzo di framework. 80
7.2 Flusso di implementazione NIS2 con l'utilizzo di framework. 80

[1]ENISA. *Enisa Threat Landscape 2024*. 2024, Fig. 2.
[2]ENISA. *Enisa Threat Landscape 2024*. 2024, Fig. 6.
[3]Clusit. *Rapporto Clusit sulla Cybersecurity in Italia e nel mondo*. 2025, Fig. 24.
[4]NIST. *The NIST Cybersecurity Framework (CSF) 2.0*. 2024, Fig. 2.
[5]Parmar e Miles. *Cyber Security Frameworks (CSFs): An Assessment Between the NIST CSF v2.0 and EU Standards*. IEEE. 2024, Fig. 1.

Elenco delle tabelle

2.1 Settori e soggetti coinvolti da NIS2: dettaglio e classificazione[6] 14

5.1 Confronto tra NIS2, ISO/IEC 27001:2022 e NIST CSF 2.0 – Politica per la sicurezza delle reti e dei sistemi informativi 52

5.2 Confronto tra NIS2, ISO/IEC 27001:2022 e NIST CSF 2.0 – Politica di gestione del rischio 53

5.3 Confronto tra NIS2, ISO/IEC 27001:2022 e NIST CSF 2.0 – Gestione degli incidenti 53

5.4 Confronto tra NIS2, ISO/IEC 27001:2022 e NIST CSF 2.0 – Continuità operativa e gestione delle crisi 54

5.5 Confronto tra NIS2, ISO/IEC 27001:2022 e NIST CSF 2.0 – Sicurezza della catena di fornitura 55

5.6 Confronto tra NIS2, ISO/IEC 27001:2022 e NIST CSF 2.0 – Sicurezza nell'acquisizione, nello sviluppo e nella manutenzione di sistemi e servizi ICT 55

5.7 Confronto tra NIS2, ISO/IEC 27001:2022 e NIST CSF 2.0 – Politiche e procedure per valutare l'efficacia delle misure di gestione del rischio di cybersicurezza 56

5.8 Confronto tra NIS2, ISO/IEC 27001:2022 e NIST CSF 2.0 – Buone pratiche di igiene informatica e formazione sulla sicurezza 57

5.9 Confronto tra NIS2, ISO/IEC 27001:2022 e NIST CSF 2.0 – Crittografia . 57

5.10 Confronto tra NIS2, ISO/IEC 27001:2022 e NIST CSF 2.0 – Sicurezza delle risorse umane 57

5.11 Confronto tra NIS2, ISO/IEC 27001:2022 e NIST CSF 2.0 – Controllo degli accessi 58

[6] Agenzia per la Cybersicurezza Nazionale. *Ambito di applicazione NIS2.*

5.12 Confronto tra NIS2, ISO/IEC 27001:2022 e NIST CSF 2.0 – Gestione degli asset 58
5.13 Confronto tra NIS2, ISO/IEC 27001:2022 e NIST CSF 2.0 – Sicurezza fisica e ambientale 59

6.1 Evoluzione della descrizione del ruolo del CISO[7] 64

7.2 Impatto atteso della Direttiva NIS2 per classi dimensionali e maturità organizzativa 76

[7]Kouns e Kouns. *The CISO Perspective: Understand the importance of the CISO in the cyber threat landscape*. IT Governance Publishing. 2023, Tab. 1.

Capitolo 1

Introduzione

1.1 Contesto

L'ultimo decennio, e in particolare il periodo post-pandemico, ha conosciuto una fortissima trasformazione digitale in ogni settore. Paradigmi come l'Industria 4.0 enfatizzano l'integrazione di tecnologie digitali e l'interconnessione nei processi produttivi, creando veri e propri ambienti intelligenti grazie all'adozione di strumenti come l'Internet of Things, l'Intelligenza Artificiale e i Big Data.[1][2] In questo scenario, le imprese italiane ed europee devono fronteggiare nuove minacce alla cybersicurezza e alla protezione delle informazioni, evolutesi parallelamente al progresso tecnologico.

La sicurezza (in tutte le sue declinazioni) assume dunque un ruolo sempre più centrale nel management aziendale e deve essere affrontata sempre più attraverso strategie integrate. Gli attacchi moderni non sono più soltanto fisici o informatici, ma una combinazione di entrambi, incrementando la complessità della gestione. La valutazione e mitigazione del rischio, la definizione di una soglia di rischio accettabile per gli stakeholder e la resilienza delle infrastrutture aziendali rappresentano oggi temi cruciali per figure come il CISO (Chief Information Security Officer), sia a livello di singola organizzazione sia lungo l'intera catena di fornitura.

[1] Clusit. *Rapporto Clusit sulla Cybersecurity in Italia e nel mondo.* 2025, pp. 1–2.
[2] ENISA. *Enisa Threat Landscape 2024.* 2024, pp. 3–4.

1.2 Minacce alla sicurezza informatica

Per avere una visione completa sui rischi che le imprese devono gestire e sugli attacchi da fronteggiare, è utile considerare i principali report di settore, che offrono un quadro aggiornato sulle minacce e sulle opportunità di rafforzamento dei sistemi di difesa. Tra i riferimenti più autorevoli si annoverano:

- **ENISA Threat Landscape 2024**: rapporto annuale dell'Agenzia dell'Unione europea per la cybersicurezza, che fornisce una panoramica sulle principali minacce, tendenze e vulnerabilità a livello europeo.
- **Rapporto Clusit 2025**: pubblicazione dell'Associazione Italiana per la Sicurezza Informatica, che analizza l'andamento degli attacchi informatici e delle tecniche utilizzate con focus specifico sul contesto italiano.

Entrambi i report rilevano, come si può immaginare, un trend di continua crescita degli episodi di incidenti informatici rilevati negli ultimi anni. Inoltre, sottolineano come il quadro geopolitico internazionale contribuisca in modo significativo al proliferare di tali eventi. Sebbene infatti il *cybercrime* sia costantemente la categoria di attaccanti più prolifica[3], il moltiplicarsi dei conflitti globali e di fenomeni appartenenti alla sfera dell'*hacktivism* costituiscono fattori sempre più rilevanti nelle statistiche sugli attacchi. Tuttavia, la presente tesi si concentrerà esclusivamente sugli aspetti di cybersicurezza in ambito aziendale, lasciando sullo sfondo le dimensioni prettamente militari e geopolitiche.

1.2.1 Europa

Il *Threat Landscape 2024* di ENISA individua le principali minacce che colpiscono l'ecosistema digitale europeo. Tra luglio 2023 e giugno 2024 ENISA ha registrato 11,079 incidenti, di cui 322 con un impatto su più paesi dell'Unione[4]. DDoS e ransomware si confermano le minacce più significative dal punto di vista numerico, mentre phishing e social engineering, sempre più potenziati dagli strumenti di intelligenza artificiale, risultano in forte crescita sia per volume sia per efficacia (Fig. 1.1).

A livello europeo, gli attacchi risultano distribuiti trasversalmente tra i diversi settori, evidenziando come gli attori malevoli non concentrino le proprie attività su un unico

[3]Clusit. *Rapporto Clusit sulla Cybersecurity in Italia e nel mondo*. 2025, p. 22.
[4]ENISA. *Enisa Threat Landscape 2024*. 2024, p. 12.

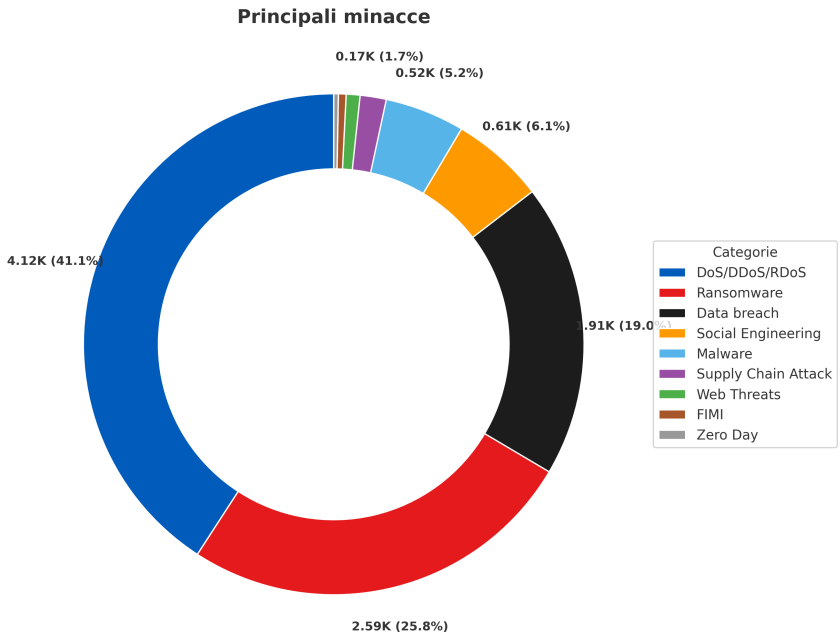


Figura 1.1: Ripartizione degli incidenti analizzati per tipologia di minaccia[5]

ambito specifico (Fig. 1.2). La cybersicurezza presenta pertanto come una sfida che interessa l'intero tessuto economico e sociale, coinvolgendo tutti senza distinzioni rilevanti.

ENISA evidenzia un incremento degli attacchi alle catene di fornitura, sfruttando i rapporti di fiducia tra imprese, fornitori e partner tecnologici come vettori per la propagazione delle minacce attraverso le reti.[7] Attacchi alla supply chain rappresentano una minaccia trasversale a più domini, che richiede un approccio ampio alla gestione del rischio, volto al monitoraggio di tutte le dipendenze critiche.

Il report segnala anche la crescita delle compromissioni degli ambienti cloud, sempre più utilizzati dalle organizzazioni per la gestione dei dati, a riprova del fatto che gli attacchi data-related restano tra i principali obiettivi degli attaccanti, rappresentando una fonte remunerativa di grande rilevanza[8].

1.2.2 Italia

Il quadro delineato dal *Rapporto Clusit 2025* conferma in larga parte, a livello nazionale, le tendenze individuate da ENISA. Nel 2024 in Italia si è registrato un aumento del 15,2% degli attacchi rispetto all'anno precedente, mentre la quota di incidenti registrati

[7]ENISA. *Enisa Threat Landscape 2024*. 2024, pp. 12–13.
[8]ENISA. *Enisa Threat Landscape 2024*. 2024, p. 17.

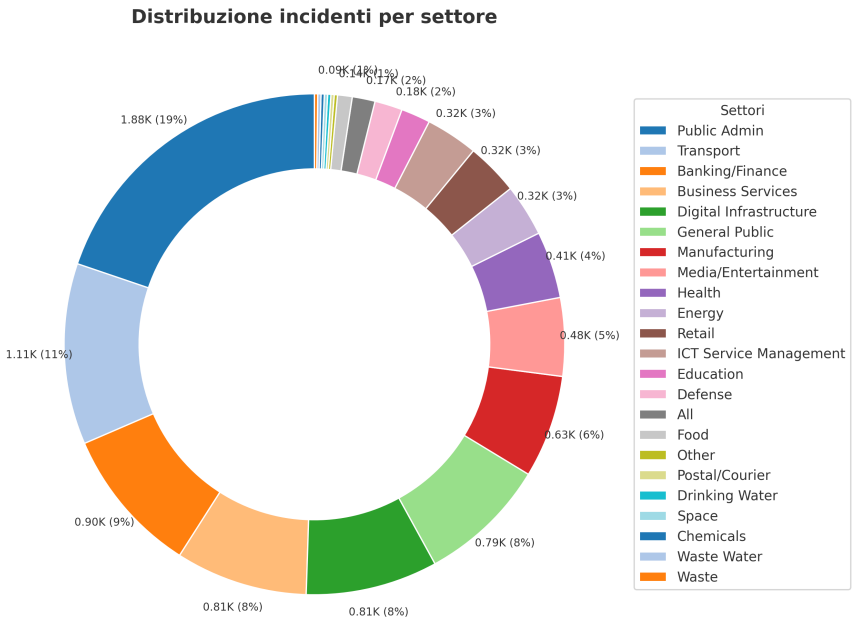


Figura 1.2: Settori colpiti per numero di incidenti[6]

nel Paese è superiore del 10% rispetto al dato globale, segno di una persistente fragilità nella sicurezza dei sistemi informatici italiani[9]. Un elemento di riflessione in questo senso è la sproporzione tra il peso economico dell'Italia e l'incidenza degli attacchi: a fronte di un PIL pari a circa l'1,8% di quello mondiale, il Paese concentra il 10,1% degli incidenti informatici globali[10]. Si segnala comunque che il trend di crescita del numero di incidenti in Italia nel 2024 rimane inferiore rispetto al resto del mondo (Fig. 1.3).

Un dato significativo riguarda la gravità degli incidenti: gli incidenti classificati come critici rappresentano solo il 9% in Italia, contro il dato globale del 29%. Come sottolineato dal Clusit, questo dato, da un lato, rappresenta sicuramente un segnale positivo per le infrastrutture IT, ma dall'altro potrebbe indicare che le organizzazioni italiane sono più spesso vittime di attacchi meno gravi e dunque presentano una vulnerabilità superiore alla media[12]

I dati dell'Osservatorio Cybersecurity del Politecnico di Milano confermano queste ipotesi, evidenziando come gli incidenti riportati dalle grandi aziende italiane nel 37% dei casi non abbiano avuto conseguenze significative[13].

[9]Clusit. *Rapporto Clusit sulla Cybersecurity in Italia e nel mondo.* 2025, pp. 30–32.
[10]Clusit. *Rapporto Clusit sulla Cybersecurity in Italia e nel mondo.* 2025, p. 30.
[12]Clusit. *Rapporto Clusit sulla Cybersecurity in Italia e nel mondo.* 2025, pp. 41–42.
[13]Clusit. *Rapporto Clusit sulla Cybersecurity in Italia e nel mondo.* 2025, p. 42.

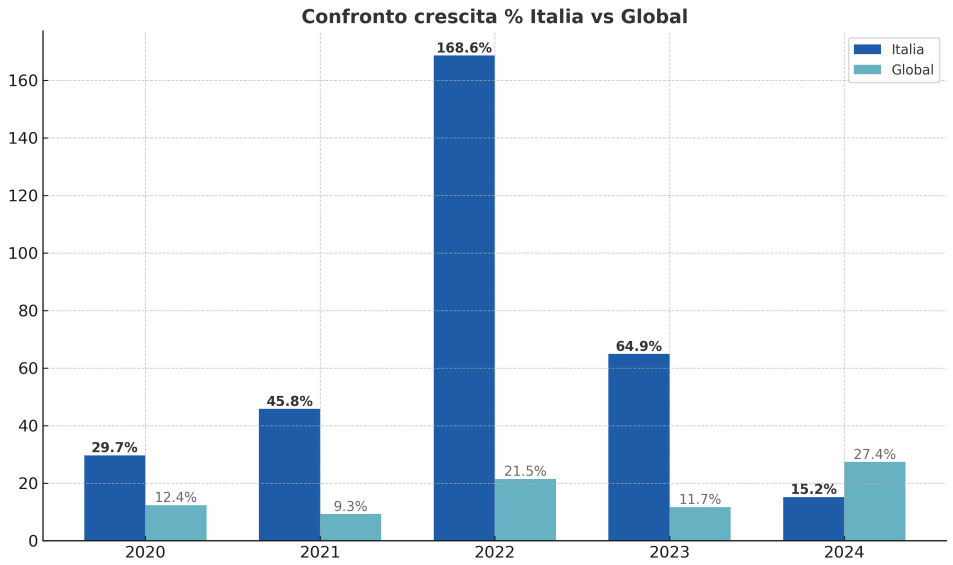


Figura 1.3: Crescita percentuale in Italia a confronto con il dato globale[11]

1.3 Standard internazionali e direttive europee

Per supportare la gestione aziendale e fronteggiare le crescenti minacce informatiche, negli anni sono stati sviluppati diversi standard e framework internazionali, con l'obiettivo di promuovere buone pratiche condivise. Tra i più diffusi si segnalano lo *Standard ISO/IEC 27001:2022* e il *NIST Cybersecurity Framework (CSF) 2.0*, oggi strumenti di riferimento per la gestione della sicurezza delle informazioni e del rischio cyber, oltre che per l'attuazione di un efficace sistema difensivo[14].

La Prassi di Riferimento UNI/PdR 174:2025 riassume efficacemente scopi e differenze dei due standard:

> *"ISO/IEC 27001 definisce i requisiti per stabilire, attuare, mantenere e migliorare in modo continuo un SGSI (Sistema di Gestione per la Sicurezza delle Informazioni), consentendone la certificazione volontaria. Tale sistema è basato sulla gestione del rischio e sulla determinazione dei controlli necessari a trattarlo.*[15] *"*

> *"Il NIST Cybersecurity Framework (CSF) 2.0 è una guida utilizzata da organizzazioni di diversa natura per gestire in modo strutturato i rischi di cybersecurity. La guida è centrata su una tassonomia di obiettivi che consentono di*

[14]UNI. *UNI/PdR 174:2025*. 2025, p. 4.
[15]UNI. *UNI/PdR 174:2025*. 2025, p. 4.

> *comprendere, valutare, pianificare, prioritizzare e comunicare le attività volte a ridurre l'esposizione ai rischi informatici.*[16] "

Parallelamente, in ambito europeo prosegue il processo normativo sulla cybersicurezza. La *Direttiva (UE) 2022/2555*, nota come NIS2, è stata adottata dal Parlamento europeo e dal Consiglio il 14 dicembre 2022, abrogando la precedente *Direttiva (UE) 2016/1148* (NIS). NIS2 introduce misure vincolanti per garantire un livello comune elevato di cybersicurezza nell'Unione[17], rappresentando un punto di svolta per le organizzazioni chiamate ad adeguarsi.

Essendo il 2024 l'anno di effettiva entrata in vigore della direttiva e visto il grande numero di soggetti interessati, soprattutto in Italia, è ancora presto per trarre conclusioni definitive sul suo impatto nel settore della cybersicurezza. Tuttavia, è ragionevole attendersi che obblighi e sanzioni previsti spingano le aziende a porre maggiore attenzione alla sicurezza, come è già avvenuto nel settore finanziario, uno tra i più normati recentemente con misure quali la DORA, in cui si osserva una riduzione del numero di incidenti rispetto ai dati storici[18].

1.4 Cosa cambia per le aziende

Le implicazioni organizzative dello scenario presentato sono evidenti: l'aumento della superficie d'attacco e la crescente sofisticazione delle minacce richiedono un approccio integrato di governance e di gestione del rischio. Come sottolinea il Clusit,

> *"La capacità di determinare, anticipare e gestire le evoluzioni legate alle minacce esogene, oltre che al contesto interno dell'organizzazione, è ormai fondamentale.*[19] "

La priorità deve essere data alla governance della sicurezza e al presidio dei rischi specifici dell'azienda, realizzando misure preventive, mitigative o trasferendo queste responsabilità laddove necessario. Anche il tema della formazione del personale, soprattutto

[16] UNI. *UNI/PdR 174:2025*. 2025, p. 4.
[17] Unione Europea. *Direttiva (UE) 2022/2555 del Parlamento Europeo e del Consiglio del 14 dicembre 2022 relativa a misure per un livello comune elevato di cibersicurezza nell'Unione (NIS 2)*, art. 1.
[18] Clusit. *Rapporto Clusit sulla Cybersecurity in Italia e nel mondo*. 2025, pp. 5–6.
[19] Clusit. *Rapporto Clusit sulla Cybersecurity in Italia e nel mondo*. 2025, p. 43.

nelle unità organizzative esposte a maggior rischio, ricopre un ruolo centrale: l'errore umano rappresenta ancora oggi uno dei primi punti di accesso per i cybercriminali alle imprese (basti pensare agli attacchi di phishing, anch'essi in crescita[20]). La resilienza digitale deve rappresentare un elemento essenziale del "patto di fiducia" tra cittadini, imprese e istituzioni, obiettivo che costituisce uno dei pilastri fondamentali su cui si erge NIS2[21].

1.5 Obiettivo

ISO/IEC 27001, NIST CSF e la Direttiva NIS2 costituiscono i principali riferimenti per la gestione della cybersicurezza aziendale e, al contempo, pongono questioni rilevanti di *governance* e responsabilità. Gli standard internazionali forniscono un linguaggio comune e un metodo strutturato per organizzare controlli e processi; la Direttiva NIS2 introduce invece obblighi giuridici vincolanti, responsabilità dirette del vertice aziendale e un regime sanzionatorio significativo.

Pur condividendo l'obiettivo di innalzare il livello di sicurezza e resilienza, ciascuno di questi strumenti presenta approcci e requisiti differenti: gli standard costituiscono una solida base metodologica, ma non sono di per sé sufficienti a garantire la piena conformità normativa, che richiede l'adozione di misure aggiuntive e specifiche per la singola azienda.

A partire da tali presupposti, l'elaborato persegue due obiettivi principali:

1. Chiarire il rapporto tra strumenti volontari e obblighi normativi: evidenziare in che misura l'adozione di ISO/IEC 27001:2022 e del NIST CSF 2.0 possa agevolare (ma non sostituire) la piena conformità a NIS2, distinguendo le aree di sovrapposizione da quelle che richiedono misure aggiuntive specifiche per la singola impresa.

2. Analizzare le implicazioni organizzative della direttiva e il ruolo del CISO: indagare come gli obblighi di NIS2 si traducano in responsabilità operative e decisionali per il CISO e per il top management, anche alla luce delle evidenze emerse dalle interviste a professionisti del settore, e come gli standard internazionali possano fungere da strumenti di supporto all'attuazione.

In generale, l'elaborato si propone di analizzare, nella consapevolezza che il tema resti ampio e con l'auspicio di offrire un contributo utile alla ricerca in materia, come le

[20] Clusit. *Rapporto Clusit sulla Cybersecurity in Italia e nel mondo.* 2025, p. 44.
[21] Clusit. *Rapporto Clusit sulla Cybersecurity in Italia e nel mondo.* 2025, p. 45.

imprese si adeguino alla Direttiva NIS2, quali nuove responsabilità e sfide essa comporti per il management e in che modo si rapporti agli standard internazionali menzionati. La comprensione del ruolo di ISO/IEC 27001 e NIST CSF e delle responsabilità della figura del CISO nel processo di attuazione dei requisiti della Direttiva NIS2 costituirà dunque il nucleo centrale dell'analisi sviluppata nei capitoli successivi.

1.6 Metodologia

La metodologia adottata nell'elaborato si articola su tre aspetti, con l'obiettivo di integrare l'analisi teorica e documentale con l'evidenza empirica e di restituire una visione completa delle implicazioni organizzative della Direttiva NIS2.

In primo luogo, viene svolta un'analisi della Direttiva NIS2, dello standard *ISO/IEC 27001:2022* e del *NIST Cybersecurity Framework (CSF) 2.0*. Tale fase si basa su una revisione sistematica della letteratura scientifica in merito, dei testi normativi e degli standard di riferimento, nonché su studi e linee guida elaborate da enti nazionali ed europei (ad esempio ENISA ed ECSO). Lo scopo è evidenziare punti di convergenza e divergenza tra strumenti di regolazione vincolante e framework di cybersicurezza, valutando in che misura questi ultimi possano agevolare, ma non sostituire, come si vedrà, la piena compliance alla normativa europea.

Successivamente, l'elaborato propone un confronto strutturato tra i tre strumenti, con un approccio di *gap analysis*. Questa parte ha l'obiettivo di rendere immediatamente visibile il grado di copertura dei requisiti della Direttiva da parte degli standard, mettendo in luce le aree in cui un'organizzazione deve implementare misure aggiuntive. A tal fine, nel Capitolo 5 è presentata una tabella di mappatura che delinea l'allineamento delle misure prescritte dall'Art. 21 della Direttiva NIS2 con gli *outcome* esposti nell'allegato del framework NIST e i controlli dell'*Annex A* di ISO 27001.

Infine, l'analisi condotta viene integrata da un'indagine empirica basata su interviste a Chief Information Security Officer (CISO) di grandi aziende italiane. Tale approccio consente di cogliere la prospettiva gestionale e strategica delle figure direttamente coinvolte nell'attuazione delle misure di cybersicurezza. In particolare, sono stati intervistati:

- Matteo Herin, CISO & Head of AI Cybersecurity presso Carrefour Italia (intervista individuale condotta dall'autore in data 10/09/2025);

- Michele Rivieri, CISO di Prometeia (intervista individuale condotta dall'autore in data 17/09/2025).

Le interviste hanno l'obiettivo di approfondire il ruolo del CISO, le responsabilità operative e decisionali derivanti dall'attuazione della Direttiva NIS2, nonché le modalità con cui gli standard internazionali possono concretamente supportarne l'implementazione in azienda. Le considerazioni emerse vengono discusse in relazione alle evidenze tratte dai documenti analizzati, evidenziando criticità, opportunità e *trade-off* organizzativi per il top management.

Si segnala che il campione di intervistati, limitato a grandi organizzazioni, non permette di rappresentare pienamente la varietà di realtà imprenditoriali interessate dalla Direttiva NIS2, in particolare le PMI, essenza del tessuto imprenditoriale italiano nonché le entità maggiormente esposte a vincoli di risorse, fortemente rilevanti in fase di implementazione delle misure di cybersicurezza. Tuttavia, l'obiettivo non è fornire un quadro esaustivo di tutte le casistiche, anché perchè arduo, bensì illustrare le principali implicazioni organizzative e gestionali della Direttiva attraverso evidenze empiriche e presentare una riflessione critica sul ruolo degli standard internazionali come strumenti di supporto al management.

Capitolo 2

Implicazioni organizzative della Direttiva NIS2

2.1 Confronto tra le Direttive NIS e NIS2

La *Direttiva (UE) 2016/1148*[1], nota come direttiva NIS, ha rappresentato il primo tentativo del legislatore europeo di armonizzare la cybersicurezza all'interno dell'Unione.

La direttiva mirava a innalzare il livello di sicurezza delle reti e dei sistemi informativi, istituendo un quadro comune volto a garantire maggiore uniformità tra gli Stati membri sugli standard minimi di cybersicurezza e di resilienza alle minacce. La sua adozione ha avuto implicazioni rilevanti sul piano organizzativo, in quanto ha riconosciuto formalmente la rilevanza strategica delle infrastrutture digitali per il mercato interno e ha introdotto, per la prima volta a livello europeo, un approccio uniforme di contrasto alle minacce informatiche basato sulla gestione del rischio.

Nonostante il suo ruolo pionieristico, la prima direttiva NIS ha mostrato evidenti limiti che ne hanno ridotto l'efficacia e l'impatto rispetto alle aspettative. In primo luogo, il recepimento a livello dei singoli Stati membri si è dimostrato fortemente disomogeneo, producendo un quadro frammentato a livello europeo[2]. Inoltre, la normativa presentava anche un problema intrinseco: il suo campo di applicazione era troppo ristretto,

[1] Unione Europea. *Direttiva (UE) 2016/1148 del Parlamento Europeo e del Consiglio del 6 luglio 2016 recante misure per un livello comune elevato di sicurezza delle reti e dei sistemi informativi nell'Unione (NIS).*

[2] Vandezande. *Cybersecurity in the EU: How the NIS2-directive stacks up against its predecessor.* Elsevier Ltd. 2024, p. 5.

includendo soltanto alcuni settori considerati critici (energia, trasporti, bancario, finanziario, sanità, acqua potabile e infrastrutture digitali). Il limitato raggio di azione ha rappresentato un grosso limite nel tentativo di diffondere un approccio uniforme, escludendo importanti aree anch'esse sensibili alle minacce informatiche[3]. A ciò si aggiungeva la debolezza dei meccanismi di supervisione e sanzione, lasciati in larga misura alla discrezionalità nazionale, con conseguenti disparità nel livello di implementazione e nella deterrenza effettiva[4].

In risposta a tali criticità, l'Unione europea ha adottato la *Direttiva (UE) 2022/2555* (NIS2), entrata in vigore a gennaio 2023 e destinata ad abrogare la NIS dal 18 ottobre 2024. NIS2 rafforza la portata delle misure previste dal testo precedente ampliando i settori di interesse, introducendo la distinzione tra soggetti essenziali e importanti, imponendo requisiti più specifici di gestione del rischio e notificazione degli incidenti, nonché un regime sanzionatorio più severo e uniforme a livello europeo. Anche l'obiettivo dichiarato evolve verso l'attenzione alla cybersicurezza in senso più ampio: non si limita alla protezione della rete e dei sistemi informatici, ma anche degli utenti di tali sistemi e di tutti coloro interessati dalle minacce[5]. In questo senso, NIS2 si pone come il primo passo verso un framework europeo per la cybersicurezza, dimostrando una forte vocazione operativa nelle misure prescritte.

2.2 Misure principali della Direttiva NIS2

2.2.1 Ambiti e soggetti coinvolti

In linea generale, rientrano nel campo di applicazione della direttiva tutte le imprese di medie e grandi dimensioni che operano nei settori individuati dal legislatore come rilevanti per la resilienza dell'Unione[6]. Le micro e piccole imprese non sono dunque contemplate, salvo i casi in cui forniscano servizi di natura critica, svolgano un ruolo

[3]Teichmann. *Cybersecurity of critical infrastructure in Europe: the NIS2 directive in focus*. Springer Fachmedien Wiesbaden GmbH, part of Springer Nature. 2025, p. 209.

[4]Vandezande. *Cybersecurity in the EU: How the NIS2-directive stacks up against its predecessor*. Elsevier Ltd. 2024, p. 6.

[5]Vandezande. *Cybersecurity in the EU: How the NIS2-directive stacks up against its predecessor*. Elsevier Ltd. 2024, p. 5.

[6]Unione Europea. *Direttiva (UE) 2022/2555 del Parlamento Europeo e del Consiglio del 14 dicembre 2022 relativa a misure per un livello comune elevato di cibersicurezza nell'Unione (NIS 2)*, art. 2.

unico o rappresentino un monopolio, forniscano servizi ad un soggetto interessato o siano specificatamente designate dal rispettivo Stato membro.

All'interno di tutti gli attori così individuati, la normativa introduce una distinzione in due categorie:

- **Soggetti essenziali**, ossia gli operatori di settori la cui interruzione avrebbe conseguenze sistemiche per la società e l'economia (tra cui energia, trasporti, sanità, infrastrutture digitali)[7]. Per la loro rilevanza strategica, questi soggetti sono sottoposti a controlli regolari *ex ante* da parte delle autorità competenti, che verificano l'adempimento in materia NIS2[8].

- **Soggetti importanti**, ossia gli operatori che, pur non raggiungendo lo stesso livello di criticità sistemica, svolgono comunque un ruolo rilevante per la continuità dei servizi e della catena del valore (tra cui servizi postali, produzione alimentare, gestione dei rifiuti)[9]. Per essi, la vigilanza avviene prevalentemente *ex post*, cioè a seguito di incidenti o segnalazioni di non conformità[10].

Questa distinzione consente di graduare gli obblighi, i meccanismi di vigilanza e le eventuali sanzioni in base alla posizione ricoperta dalle organizzazioni e al loro impatto potenziale sulla resilienza complessiva dell'Unione.

L'estensione dell'ambito soggettivo comporta conseguenze rilevanti: molte imprese che prima non erano soggette a obblighi specifici di cybersicurezza devono ora implementare sistemi strutturati di gestione del rischio, rafforzare le proprie capacità di rilevazione e risposta agli incidenti e predisporre procedure di comunicazione rapide ed efficaci con le autorità di vigilanza.

2.2.2 Gestione del rischio

L'elemento cardine su cui si fonda la Direttiva NIS2 è la gestione del rischio quale base delle pratiche e delle politiche di sicurezza. L'articolo 21 sancisce esplicitamente l'obbligo,

[7]Unione Europea. *Direttiva (UE) 2022/2555 del Parlamento Europeo e del Consiglio del 14 dicembre 2022 relativa a misure per un livello comune elevato di cibersicurezza nell'Unione (NIS 2)*, Allegato I.

[8]Unione Europea. *Direttiva (UE) 2022/2555 del Parlamento Europeo e del Consiglio del 14 dicembre 2022 relativa a misure per un livello comune elevato di cibersicurezza nell'Unione (NIS 2)*, art. 32.

[9]Unione Europea. *Direttiva (UE) 2022/2555 del Parlamento Europeo e del Consiglio del 14 dicembre 2022 relativa a misure per un livello comune elevato di cibersicurezza nell'Unione (NIS 2)*, Allegato II.

[10]Unione Europea. *Direttiva (UE) 2022/2555 del Parlamento Europeo e del Consiglio del 14 dicembre 2022 relativa a misure per un livello comune elevato di cibersicurezza nell'Unione (NIS 2)*, art. 33.

Tabella 2.1: Settori e soggetti coinvolti da NIS2: dettaglio e classificazione[11]

Settore	Dettaglio	Grandi imprese	Medie imprese	Piccole e micro imprese
SETTORI ALTAMENTE CRITICI				
Energia	19 tipologie di soggetto	Essenziali	Importanti	Fuori ambito
Trasporti	10 tipologie di soggetto	Essenziali	Importanti	Fuori ambito
Settore bancario	DORA *lex specialis*	Essenziali	Importanti	Fuori ambito
Infrastrutture dei mercati finanziari	DORA *lex specialis*	Essenziali	Importanti	Fuori ambito
Settore sanitario	5 tipologie di soggetto	Essenziali	Importanti	Fuori ambito
Acqua potabile	1 tipologia di soggetto	Essenziali	Importanti	Fuori ambito
Acque reflue	1 tipologia di soggetto	Essenziali	Importanti	Fuori ambito
Infrastrutture digitali	9 tipologie di soggetto	Essenziali	Essenziali/Importanti/Fuori ambito	Essenziali/Importanti/Fuori ambito
Gestione dei servizi TIC (B2B)	2 tipologie di soggetto	Essenziali	Importanti	Fuori ambito
Spazio	1 tipologia di soggetto	Essenziali	Importanti	Fuori ambito
SETTORI CRITICI				
Servizi postali e di corriere	1 tipologia di soggetto	Importanti	Importanti	Fuori ambito
Gestione dei rifiuti	1 tipologia di soggetto	Importanti	Importanti	Fuori ambito
Fabbricazione, produzione e distribuzione di sostanze chimiche	1 tipologia di soggetto	Importanti	Importanti	Fuori ambito
Produzione, trasformazione e distribuzione di alimenti	1 tipologia di soggetto	Importanti	Importanti	Fuori ambito
Fabbricazione	6 tipologie di soggetto	Importanti	Importanti	Fuori ambito
Fornitori di servizi digitali	4 tipologie di soggetto	Importanti/Fuori ambito	Importanti/Fuori ambito	Importanti/Fuori ambito
Ricerca	2 tipologie di soggetto	Importanti	Importanti	Fuori ambito
ULTERIORI TIPOLOGIE DI SOGGETTI				
Pubblica Amministrazione centrale	4 categorie di PA	Essenziali	Essenziali	Essenziali
Pubblica Amministrazione regionale e locale	11 categorie di PA	Importanti	Importanti	Importanti
Ulteriori tipologie di soggetti	4 tipologie di soggetti	Identificazione dell'Autorità	Identificazione dell'Autorità	Identificazione dell'Autorità

per i soggetti interessati, di adottare misure tecniche, operative e organizzative adeguate e proporzionate al rischio cui è esposta l'azienda o l'area dell'azienda in questione[12]. Ciò significa che alcuni controlli possono applicarsi sempre o solamente in corrispondenza di livelli di rischio superiori alle soglie fissate internamente dall'impresa, che in ogni caso ha l'onere di documentare e giustificare le proprie scelte[13].

Il Regolamento di esecuzione (UE) 2024/2690, che stabilisce le norme per l'applicazione della direttiva, specifica ulteriormente i requisiti tecnici e metodologici connessi all'articolo 21, delineando un insieme di pratiche di governance del rischio che i soggetti interessati sono tenuti ad applicare. In particolare, il regolamento stabilisce che le politiche di sicurezza e le procedure di gestione del rischio siano formalizzate, approvate dagli organi direttivi e soggette a revisione periodica, rafforzando l'idea che la gestione del rischio costituisca un processo sistematico e continuativo[14]. Inoltre, esse devono essere soggette a revisione almeno ogni due anni o comunque a seguito di incidenti significativi, variazioni organizzative o mutamenti del contesto delle minacce in cui si opera.

Infine, ENISA dettaglia una *Risk Management Policy* che preveda indicatori e misure

[12]Unione Europea. *Direttiva (UE) 2022/2555 del Parlamento Europeo e del Consiglio del 14 dicembre 2022 relativa a misure per un livello comune elevato di cibersicurezza nell'Unione (NIS 2)*, art. 21.

[13]Commissione Europea. *Regolamento di esecuzione (UE) 2024/2690 della Commissione del 17 ottobre 2024 che stabilisce norme per l'applicazione della direttiva (UE) 2022/2555*, art. 2.

[14]Commissione Europea. *Regolamento di esecuzione (UE) 2024/2690 della Commissione del 17 ottobre 2024 che stabilisce norme per l'applicazione della direttiva (UE) 2022/2555*, Allegato.

per monitorare maturità e performance, liste di policy e una chiara attribuzione di ruoli/responsabilità, in modo che gli esiti di compliance e review alimentino coerentemente il ciclo decisionale del management (risk acceptance documentata, piani correttivi, riesami almeno annuali o a seguito di incidenti significativi).[15].

2.2.3 Misure di cybersicurezza

NIS2 introduce un quadro prescrittivo di misure minime che tutte le entità rientranti nel campo di applicazione devono adottare. L'articolo 21, paragrafo 2, elenca una serie di ambiti specifici che costituiscono il nucleo essenziale della sicurezza informatica richiesta: politiche di analisi e gestione del rischio, capacità di gestione degli incidenti, misure di continuità operativa e piani di disaster recovery, sicurezza della supply chain e delle relazioni con i fornitori (*Third Party Risk Management*), requisiti di sicurezza per lo sviluppo e la manutenzione dei sistemi, testing e auditing periodici, impiego della crittografia e di adeguati sistemi di controllo degli accessi, formazione del personale e pratiche di *cyber hygiene*[16].

Il regolamento di esecuzione, come nel caso precedente, precisa i requisiti tecnici e metodologici delle misure di cui all'articolo 21. Esso stabilisce che le politiche di sicurezza devono essere formalizzate in documenti approvati dagli organi direttivi, rese disponibili all'interno dell'organizzazione e sottoposte a revisione periodica o a riesame in occasione di incidenti significativi e di mutamenti rilevanti del contesto di rischio[17].

Le misure minime di sicurezza devono comprendere la definizione di ruoli e responsabilità interne, la gestione della supply chain e l'inclusione di clausole contrattuali con i fornitori, la gestione delle vulnerabilità, la protezione degli asset lungo il loro ciclo di vita, procedure di autenticazione forte e controllo degli accessi, misure di sicurezza fisica, protezione dei dati e delle comunicazioni, monitoraggio degli eventi di sicurezza e procedure di risposta agli incidenti e di ripristino[18].

[15]Moulinos, Theocharidou e ENISA. *Implementing Guidance on Commission Implementing Regulation (EU) 2024/2690 of 17.10.2024 laying down rules for the application of Directive (EU) 2022/2555 as regards technical and methodological requirements of cybersecurity risk-management measures.* 2024, pp. 9–25.

[16]Unione Europea. *Direttiva (UE) 2022/2555 del Parlamento Europeo e del Consiglio del 14 dicembre 2022 relativa a misure per un livello comune elevato di cibersicurezza nell'Unione (NIS 2)*, art. 21.

[17]Commissione Europea. *Regolamento di esecuzione (UE) 2024/2690 della Commissione del 17 ottobre 2024 che stabilisce norme per l'applicazione della direttiva (UE) 2022/2555*, art. 3.

[18]Commissione Europea. *Regolamento di esecuzione (UE) 2024/2690 della Commissione del 17 ottobre 2024 che stabilisce norme per l'applicazione della direttiva (UE) 2022/2555*, Allegato.

La specificazione puntuale dei controlli che i soggetti devono implementare è lasciata ai singoli Stati membri, secondo quanto previsto dagli ordinamenti nazionali.

2.2.4 Obblighi di notifica

Un'ulteriore misura introdotta da NIS2 riguarda il regime dettagliato in materia di notifica degli incidenti di sicurezza. L'articolo 23 disciplina le modalità e le tempistiche di segnalazione alle autorità competenti e ai CSIRT nazionali. La direttiva prevede che entro 24 ore dall'avvenuta rilevazione di un incidente debba essere trasmessa una comunicazione preliminare, seguita entro 72 ore da una notifica completa contenente una prima valutazione dell'impatto e delle misure adottate[19]. Entro un mese dall'incidente, l'entità è tenuta a fornire una relazione finale che includa analisi approfondita delle cause, impatto sui servizi e misure correttive adottate. La normativa contempla inoltre la possibilità di relazioni intermedie, quando la gestione dell'incidente lo renda necessario.

2.2.5 Governance aziendale e responsabilità

Un aspetto innovativo e centrale della direttiva è l'introduzione di responsabilità specifiche per gli organi di gestione delle entità incluse nel campo di applicazione. L'articolo 20 sancisce infatti che i membri degli organi di amministrazione, di direzione o di supervisione siano direttamente responsabili dell'approvazione delle misure di gestione del rischio e della supervisione della loro attuazione[20]. La direttiva richiede inoltre che gli organi di gestione garantiscano che i dipendenti ricevano formazione adeguata e regolare in materia di cybersicurezza, al fine di conoscere ed applicare in maniera consapevole le misure predisposte.

Il regolamento di esecuzione rafforza ulteriormente tale approccio, richiedendo che le responsabilità siano chiaramente attribuite, mediante la creazione di un framework aziendale, così da garantire una gerarchia aziendale ben definita e favorire la supervisione attiva da parte dei livelli superiori[21].

[19] Unione Europea. *Direttiva (UE) 2022/2555 del Parlamento Europeo e del Consiglio del 14 dicembre 2022 relativa a misure per un livello comune elevato di cibersicurezza nell'Unione (NIS 2)*, art. 23.

[20] Unione Europea. *Direttiva (UE) 2022/2555 del Parlamento Europeo e del Consiglio del 14 dicembre 2022 relativa a misure per un livello comune elevato di cibersicurezza nell'Unione (NIS 2)*, art. 20.

[21] Commissione Europea. *Regolamento di esecuzione (UE) 2024/2690 della Commissione del 17 ottobre 2024 che stabilisce norme per l'applicazione della direttiva (UE) 2022/2555*, Allegato.

La responsabilità dei vertici aziendali si estende anche alle conseguenze in caso di inadempienza. Sono infatti previste sanzioni amministrative pecuniarie e, nei casi più gravi, misure che possono includere la sospensione temporanea dei dirigenti responsabili dai rispettivi incarichi.

2.3 Direttiva NIS2 in Italia: ACN e CSIRT Italia

Il recepimento della Direttiva NIS2 in Italia è avvenuto con il *Decreto Legislativo del 4 settembre 2024, n. 138*, entrato in vigore nell'ottobre 2024[22]. Il decreto riprende le principali disposizioni della direttiva, precisa le modalità di applicazione a livello nazionale e specifica l'attribuzione dei compiti di vigilanza e ricezione delle notifiche all'ACN e al CSIRT Italia.

L'ACN (Agenzia per la Cybersicurezza Nazionale), istituita nel 2021 come agenzia governativa con il compito di proteggere gli interessi nazionali in materia di cybersicurezza, ricopre un ruolo centrale nella supervisione delle entità NIS2 essenziali e importanti. I suoi compiti principali riguardano la vigilanza sul rispetto degli obblighi di gestione del rischio, la ricezione delle notifiche di incidenti significativi, l'adozione di provvedimenti correttivi e la comminazione delle sanzioni[23].

Inoltre, all'ACN è attribuita la facoltà di emanare linee guida vincolanti e istruzioni operative. Tra i documenti più importanti prodotti dall'agenzia, vi sono la Determinazione ACN 164179[24] e i suoi allegati 1 e 2 riportanti rispettivamente l'elenco dettagliato delle misure di sicurezza obbligatorie rispettivamente per i soggetti importanti[25] ed essenziali[26]. Gli allegati sono resi disponibili anche in formato xls, per facilitarne l'adozione per le aziende.

Accanto all'ACN opera il CSIRT (Computer Security Incident Response Team) Italia,

[22]Repubblica Italiana. *Decreto Legislativo 4 settembre 2024, n. 138. Recepimento della Direttiva (UE) 2022/2555.*

[23]Repubblica Italiana. *Decreto Legislativo 4 settembre 2024, n. 138. Recepimento della Direttiva (UE) 2022/2555.*

[24]Agenzia per la Cybersicurezza Nazionale. *Determinazione del Direttore Generale dell'Agenzia per la cybersicurezza nazionale n. 164179/2025: modalità e specifiche di base per l'adempimento agli obblighi di cui agli artt. 23, 24, 25, 29 e 32 del d.lgs. 138/2024.*

[25]Agenzia per la Cybersicurezza Nazionale. *Allegato 1 – Misure di sicurezza di base per i soggetti importanti (alla Determinazione ACN n. 164179/2025).*

[26]Agenzia per la Cybersicurezza Nazionale. *Allegato 2 – Misure di sicurezza di base per i soggetti essenziali (alla Determinazione ACN n. 164179/2025).*

responsabile della gestione tecnica delle segnalazioni e del supporto operativo alle imprese. Il CSIRT rappresenta il punto di raccolta e analisi delle notifiche di incidente trasmesse dai soggetti NIS2 e si occupa di fornire riscontri, raccomandazioni e supporto tecnico in risposta alle segnalazioni ricevute[27]. Il suo compito è quindi cruciale per quanto riguarda la condivisione di informazioni su minacce emergenti, oltre che per la cooperazione con i CSIRT degli altri Stati membri e con ENISA.

Dal punto di vista delle imprese, l'ACN e il CSIRT costituiscono gli interlocutori designati per le questioni legate alla conformità NIS2 sul territorio italiano. La normativa nazionale prevede, a tal fine, l'obbligo per ciascun soggetto di designare una persona fisica avente il ruolo di punto di contatto interno per la cybersicurezza, con la responsabilità di mantenere un canale di comunicazione con le autorità[28]. Tale figura svolge una funzione anche strategica, assicurando che l'azienda sia pronta a segnalare incidenti e a mettere in atto le disposizioni ricevute, gestendo il flusso di informazioni provenienti dall'ACN e dal CSIRT.

2.4 Implicazioni organizzative della Direttiva NIS2

In questa sezione si analizzano le implicazioni organizzative dell'adozione della Direttiva NIS2, le sfide dal punto di vista della governance aziendale, della gestione del rischio e dell'allocazione delle risorse, nonché gli impatti sui processi interni e sulla cultura della sicurezza. Per l'analisi si segue la struttura individuata da un report condotto da Deloitte nel 2023 sulla normativa[29], organizzato in quattro sezioni:

1. responsabilità del rischio;
2. misure di sicurezza informatica;
3. sicurezza della *supply chain*;
4. notifica degli incidenti.

[27]Repubblica Italiana. *Decreto Legislativo 4 settembre 2024, n. 138. Recepimento della Direttiva (UE) 2022/2555.* art. 24.
[28]Repubblica Italiana. *Decreto Legislativo 4 settembre 2024, n. 138. Recepimento della Direttiva (UE) 2022/2555.* art. 21.
[29]Deloitte. *The NIS2 Directive.* 2023.

Inoltre, si aggiungono considerazioni sulle pratiche di formazione e igiene informatica e una riflessione sulle principali sfide che le organizzazioni si trovano ad affrontare per garantire la propria conformità alla direttiva.

2.4.1 Governance e responsabilità nella gestione del rischio

Il grande impatto di NIS2 sulla realtà aziendale è dovuto in primo luogo alla formale attribuzione della responsabilità della sicurezza agli organi dirigenziali dell'azienda. Gli esperti sottolineano come, in realtà, il CdA (Consiglio di Amministrazione) possedesse già questa responsabilità, dovendo rispondere direttamente di ciò che accade all'interno dell'organizzazione, ma la formalizzazione di ciò ha catturato l'attenzione dei manager per due motivi principali, secondo Rivieri:

- L'attribuzione diretta della responsabilità al board implica la non delegabilità della stessa (non specificata dalla direttiva); dunque, il CISO, figura di carattere tecnico, rimane responsabile solamente dell'implementazione delle misure necessarie, mentre gli amministratori rispondono anche legalmente degli eventi di sicurezza informatica e perciò sono responsabili dell'accettazione dei rischi correlati.
- La formalizzazione pubblica di tale responsabilità costituisce una leva significativa per il CISO nei confronti del top management; in assenza di adeguate competenze per valutare il rischio informatico, i vertici tendono ad affidarsi con maggiore sistematicità alle figure tecniche, anche per ridurre l'esposizione a sanzioni, portando a una maggiore rilevanza del CISO nel processo decisionale.

Il CISO, in questo contesto, rappresenta quindi il punto di incontro tra compliance normativa e attuazione tecnica. Secondo ENISA, per garantire efficacia tale figura deve disporre di risorse dedicate e autonomia decisionale, nonché della possibilità di riferire direttamente al board[30]. Il CISO deve inoltre coordinare un team multidisciplinare, cooperando con figure come *Risk Manager*, *Incident and Threat Manager*, *Compliance Officer* e *Supply Chain Security Specialist*, come suggerito da ENISA in conformità con l'ECSF (European Cybersecurity Skills Framework). Dal punto di vista delle competenze richieste, quindi, deve combinare abilità tecniche (gestione delle vulnerabilità, incident

[30] Adamos, Franco, Leventopoulos e ENISA. *Cybersecurity Roles and Skills for NIS2 Essential and Important Entities: Mapping NIS2 obligations to ECSF*. 2025, p. 23.

response) con competenze manageriali e comunicative, indispensabili per interagire con il board e guidare la cultura organizzativa della sicurezza. Scompare la figura del manager IT come tecnico verticale: oggi le aziende necessitano di leader con competenze anche strategiche, chiamati ad identificare i rischi aziendali e a supportare decisioni di investimento e governance nell'area della cybersecurity[31].

Infine, oltre all'approvazione e alla supervisione delle misure, le linee guida ENISA precisano meccanismi di compliance monitoring e di independent review a supporto del board; si ritengono necessari report indipendenti e standardizzati con metriche chiave per l'identificazione dei rischi, da presentare almeno annualmente agli organi di gestione per garantire un processo decisionale adeguatamente informato e concretizzare l'accountability richiesta da NIS2[32].

2.4.2 Misure di sicurezza

La conformità alla Direttiva NIS2 richiede alle imprese l'adozione di un insieme di misure organizzative e procedurali che integrino la cybersicurezza nei processi aziendali.

In primo luogo, la realizzazione di politiche di cybersicurezza, formalmente approvate dal board e inserite nel sistema di gestione del rischio aziendale, come parte integrante della strategia organizzativa[33]. In quest'ottica, sono essenziali il mantenimento di registri di catalogo dei rischi, la definizione di indicatori di performance relativi alla sicurezza, la presentazione di report periodici agli organi direttivi e la revisione periodica delle policy, anche in seguito a incidenti significativi.

Per raggiungere efficacemente i suoi obiettivi, NIS2 richiede un approccio trasversale, che coinvolga non solo l'area IT, ma anche i dipartimenti legale, compliance, risorse umane e approvvigionamento, oltre alle funzioni operative e al top management. Le linee guida all'implementazione della direttiva sottolineano come tale coinvolgimento si traduca in attività concrete: l'ufficio legale e la funzione compliance supportano la produzione della documentazione e delle notifiche alle autorità; le risorse umane integrano la formazione

[31] Kouns e Kouns. *The CISO Perspective: Understand the importance of the CISO in the cyber threat landscape*. IT Governance Publishing. 2023, pp. 32–34.

[32] Moulinos, Theocharidou e ENISA. *Implementing Guidance on Commission Implementing Regulation (EU) 2024/2690 of 17.10.2024 laying down rules for the application of Directive (EU) 2022/2555 as regards technical and methodological requirements of cybersecurity risk-management measures*. 2024, pp. 21–25.

[33] Commissione Europea. *Regolamento di esecuzione (UE) 2024/2690 della Commissione del 17 ottobre 2024 che stabilisce norme per l'applicazione della direttiva (UE) 2022/2555*, Allegato.

in materia di cybersicurezza nei programmi di formazione del personale e del board; la funzione di approvvigionamento deve inserire requisiti di sicurezza e clausole vincolanti nei contratti con i fornitori; il top management, infine, è chiamato a supervisionare e approvare tali misure, assumendo responsabilità dirette[34][35].

Sul piano operativo, NIS2 e le linee guida ENISA richiedono la predisposizione di procedure strutturate:

- simulazioni periodiche di risposta agli incidenti, documentate e analizzate in termini di *lessons learned*;
- audit interni regolari, finalizzati a verificare l'efficacia delle misure di sicurezza e a pianificare il miglioramento;
- testing sistematico delle difese aziendali (penetration test e vulnerability assessment, attività di competenza del CISO e del suo team di cybersicurezza), con l'obbligo di tracciarne i risultati, le azioni correttive intraprese e gli indicatori di performance associati;
- revisione delle misure e aggiornamento delle procedure a seguito di incidenti rilevanti o evoluzioni del contesto operativo.

Tutte queste attività devono essere integrate in un ciclo continuo di revisione e miglioramento, con il supporto di metriche e indicatori delle performance di sicurezza, e sostenute da un'adeguata documentazione, necessaria per dimostrare la conformità alle autorità competenti, in linea con il principio di accountability.

2.4.3 Sicurezza della supply chain

La *supply chain* rappresenta uno dei punti più vulnerabili per la resilienza complessiva delle organizzazioni[36]. Perciò, la gestione dei rischi della catena di fornitura richiede un'attenta mappatura dei fornitori critici, analizzando non solo gli interlocutori diretti ma anche quelli di secondo e terzo livello, che possono incidere sulla continuità operativa dei servizi essenziali.

[34]ECSO. *ECSO White Paper — NIS2 Implementation: Challenges & Priorities*. 2025.
[35]Moulinos, Theocharidou e ENISA. *Implementing Guidance on Commission Implementing Regulation (EU) 2024/2690 of 17.10.2024 laying down rules for the application of Directive (EU) 2022/2555 as regards technical and methodological requirements of cybersecurity risk-management measures*. 2024.
[36]ECSO. *ECSO White Paper — NIS2 Implementation: Challenges & Priorities*. 2025, pp. 22–25.

Le raccomandazioni di ECSO ed ENISA sottolineano l'importanza di integrare clausole contrattuali vincolanti nei rapporti con i fornitori, così da garantire che anche soggetti esterni adottino misure equivalenti, come richiesto dalla direttiva[37][38]. Ciò implica una stretta collaborazione tra la funzione di approvvigionamento, il CISO e l'area legale per inserire nei contratti obblighi di notifica degli incidenti, standard di sicurezza minimi e diritti di audit da parte dell'azienda cliente.

Alle clausole si devono affiancare meccanismi di monitoraggio continuo, che comprendano la valutazione periodica dei fornitori, la richiesta di attestazioni o certificazioni e, ove necessario, la conduzione di audit. NIS2 infatti non consente più di limitarsi a un approccio passivo, ma richiede di strutturare processi di supervisione attivi, sistematici e documentati[39].

Tali misure di sicurezza della supply chain introdotte da NIS2 possono rappresentare anche strumenti per ridurre i costi di coordinamento e di transazione tra imprese[40]. L'approccio regolatorio tende infatti a internalizzare i rischi, in questo caso, informatici della filiera, promuovendo clausole contrattuali, audit congiunti e standard comuni di sicurezza. Ciò rafforza la coerenza complessiva della catena, riducendo le asimmetrie che ostacolano il coordinamento e fornendo un approccio operativo comune, in linea con l'obiettivo di uniformità perseguito dalla direttiva.

Infine, un'interessante riflessione sulla *supply chain security* riguarda la potenziale nascita di un nuovo scenario competitivo: la sicurezza della filiera non è infatti solamente una questione di compliance, ma le imprese che dimostrano di aver implementato misure di sicurezza valide possono rafforzare la fiducia degli stakeholder e proporsi come partner affidabili sul mercato, guadagnando un vantaggio competitivo non indifferente rispetto ai rivali.

[37]ECSO. *ECSO White Paper — NIS2 Implementation: Challenges & Priorities*. 2025, p. 2.

[38]Moulinos, Theocharidou e ENISA. *Implementing Guidance on Commission Implementing Regulation (EU) 2024/2690 of 17.10.2024 laying down rules for the application of Directive (EU) 2022/2555 as regards technical and methodological requirements of cybersecurity risk-management measures*. 2024, p. 58.

[39]Moulinos, Theocharidou e ENISA. *Implementing Guidance on Commission Implementing Regulation (EU) 2024/2690 of 17.10.2024 laying down rules for the application of Directive (EU) 2022/2555 as regards technical and methodological requirements of cybersecurity risk-management measures*. 2024, pp. 57–63.

[40]Besanko, Dranove, Shanley e Schaefer. *Economia dell'industria e strategie d'impresa*. ISEDI. 2013.

2.4.4 Notifica degli incidenti

Un importante elemento che, come verrà approfondito nel Capitolo 4, differenzia NIS2 dagli standard internazionali è la volontà del legislatore europeo di promuovere il processo di condivisione delle informazioni relative agli eventi di cybersicurezza, in modo da diffondere la conoscenza in materia e contribuire all'innovazione. Perciò, NIS2 pone grande attenzione in merito agli obblighi di notifica degli incidenti, richiedendo alle imprese l'adozione di una timeline operativa precisa per l'*incident response*, oltre al conseguente obbligo di testare periodicamente tali misure[41].

La normativa fissa precisi KPI in caso di incidenti significativi per gli obblighi di notifica e la comunicazione con le autorità di settore. Le organizzazioni hanno ventiquattro ore di tempo per fornire una prima segnalazione di allerta ed entro settantadue ore deve seguire una comunicazione ufficiale di risposta all'incidente. Dopo un mese, deve essere emesso un rapporto finale sull'incidente oppure, se l'indagine è ancora in corso, il CSIRT può rilasciare un rapporto intermedio. In questo modo si favorisce la collaborazione tra le aziende e le agenzie governative deputate al controllo della cybersicurezza, nonché l'assistenza in caso di emergenze e la gestione coordinata delle stesse qualora interessino al tempo stesso più soggetti.

Dal punto di vista organizzativo, a tal fine ogni impresa deve designare un punto di contatto interno per la cybersicurezza, responsabile dei rapporti con l'ACN e con il CSIRT nazionale[42]. Questa figura, che deve essere una persona fisica (nel caso italiano, registrata presso l'ACN), ha il compito di garantire la trasmissione delle notifiche di incidente, i rapporti con le autorità e la diffusione interna delle istruzioni ricevute. Ciò comporta un rafforzamento del ruolo di Chief Information Security Officer (CISO), come spiegato da Matteo Herin nell'intervista realizzata per questo elaborato, il quale assorbe tali funzioni tra i suoi compiti.

[41] Adamos, Franco, Leventopoulos e ENISA. *Cybersecurity Roles and Skills for NIS2 Essential and Important Entities: Mapping NIS2 obligations to ECSF*. 2025, pp. 18–20.

[42] Repubblica Italiana. *Decreto Legislativo 4 settembre 2024, n. 138. Recepimento della Direttiva (UE) 2022/2555.* art. 21.

2.4.5 Formazione e cultura della sicurezza informatica

Un altro pilastro dell'adempimento NIS2 è rappresentato dalla formazione e dalla diffusione di una cultura della cybersicurezza a tutti i livelli aziendali. La direttiva stabilisce che i membri degli organi di gestione siano direttamente responsabili dell'approvazione delle misure di sicurezza e ne supervisionino l'attuazione[43], ma per svolgere efficacemente tali compiti devono possedere una preparazione adeguata. La formazione del board è dunque un requisito essenziale per poter garantire una gestione consapevole dei rischi e per assumersi l'accountability richiesta dal quadro normativo.

Il tema non riguarda tuttavia soltanto i vertici. La conformità alla direttiva passa anche dalla capacità di diffondere tra tutti i dipendenti pratiche di *cyber hygiene*, come l'uso sicuro delle credenziali, la gestione corretta delle informazioni aziendali e la segnalazione tempestiva di anomalie[44]. In questo senso, i programmi di formazione periodica assumono la funzione di ridurre il fattore di rischio umano, spesso l'anello più debole della catena di sicurezza.

2.4.6 Sfide per le organizzazioni

Come visto in questa sezione, l'introduzione di NIS2 nel panorama normativo richiede ingenti misure alle aziende per adattare i propri processi e la propria organizzazione alle disposizioni legislative. Ciò comporta naturalmente un notevole impiego di risorse, tema centrale data la larghissima portata della direttiva, che coinvolge soggetti profondamente diversi nella struttura, nelle dimensioni e quindi anche nelle capacità di investimento.

Appare chiaro che le entità più grandi e strutturate abbiano meno difficoltà nell'adozione di NIS2 rispetto alle aziende che per la prima volta si trovano a dover dimostrare accountability in materia di cybersicurezza. Le aziende di dimensioni maggiori e quelle che rientravano nella normativa NIS precedente o già soggette ad altre misure, come DORA per l'area economico-finanziaria, dispongono già di una struttura avanzata per la gestione della sicurezza informatica. Per questi soggetti, NIS2 rappresenta solamente un'integra-

[43] Unione Europea. *Direttiva (UE) 2022/2555 del Parlamento Europeo e del Consiglio del 14 dicembre 2022 relativa a misure per un livello comune elevato di cibersicurezza nell'Unione (NIS 2)*, art. 20.

[44] Moulinos, Theocharidou e ENISA. *Implementing Guidance on Commission Implementing Regulation (EU) 2024/2690 of 17.10.2024 laying down rules for the application of Directive (EU) 2022/2555 as regards technical and methodological requirements of cybersecurity risk-management measures.* 2024, pp. 99–103.

zione necessaria rispetto ai sistemi esistenti, con novità da introdurre soprattutto per la gestione delle terze parti, degli obblighi di notifica e delle responsabilità formali del CdA, ma senza alcun cambiamento sostanziale e profondamente impattante[45].

In questo contesto è importante notare come la capacità di integrare la sicurezza informatica nei processi decisionali e nelle strategie di business rappresenti un fattore di vantaggio competitivo, aumentando la fiducia del mercato e la continuità operativa e generando barriere all'entrata per i concorrenti meno maturi dal punto di vista organizzativo[46]. Tra essi vi sono i soggetti di dimensioni inferiori o coloro i quali per la prima volta si trovano a dover implementare misure di cybersicurezza strutturate. In questa categoria rientrano anche le aziende non classificate NIS2, ma comunque facenti parte della catena produttiva di soggetti NIS2, elemento che costringe le prime a dotarsi dei sistemi richiesti dalla direttiva. Tali organizzazioni si trovano a dover sostenere ingenti investimenti nell'ambito cyber, necessitando di sistemi nuovi da progettare ad hoc, di una revisione profonda dei processi operativi e di figure esperte che abbiano le competenze per implementare tutto il necessario, con un conseguente impatto elevato sulle proprie risorse[47].

Le aziende che si trovano in questa situazione, come si vedrà nei capitoli successivi, possono decidere di realizzare i controlli richiesti strutturando direttamente la sicurezza informatica sulle disposizioni NIS2 oppure adottando un framework che consenta loro di progettare una base solida per la cybersicurezza, su cui integrare gli adempimenti mancanti. In entrambe le casistiche, tuttavia, la complessità organizzativa rimane elevata e si richiede un'accurata pianificazione delle strategie di business e del budget per includere l'integrazione di NIS2 nei processi.

[45]ECSO. *ECSO White Paper — NIS2 Implementation: Challenges & Priorities*. 2025, pp. 2–5.
[46]Besanko, Dranove, Shanley e Schaefer. *Economia dell'industria e strategie d'impresa*. ISEDI. 2013.
[47]ECSO. *ECSO White Paper — NIS2 Implementation: Challenges & Priorities*. 2025, pp. 2–5.

Capitolo 3

Standard internazionali e framework per la cybersicurezza

3.1 Standard ISO/IEC 27001:2022

3.1.1 Scopi e struttura dello standard

L'ISO/IEC 27001:2022 è lo standard internazionale di riferimento per la gestione della sicurezza delle informazioni, con oltre 40.000 certificazioni rilasciate a livello mondiale[1].

Definisce i requisiti per l'istituzione, l'attuazione, il mantenimento e il miglioramento continuo di un *Sistema di Gestione per la Sicurezza delle Informazioni* (SGSI), con l'obiettivo di garantire la protezione della riservatezza, integrità e disponibilità delle informazioni trattate dalle organizzazioni[2]. Lo standard si propone non soltanto come mezzo tecnico, ma anche come strumento organizzativo per strutturare la sicurezza informatica nei processi e negli aspetti di governance.

Lo standard segue *Annex SL*, ovvero una struttura di alto livello comune a tutti gli standard ISO per i sistemi di gestione. Tale struttura prevede dieci capitoli[3]:

1. Scopo

[1]McIntosh, Susnjak, Liu, Watters, Xu, Liu, Nowrozy e Halgamuge. *From COBIT to ISO 42001: Evaluating cybersecurity frameworks for opportunities, risks, and regulatory compliance in commercializing large language models*. Elsevier Ltd. 2024, p. 2.

[2]ISO/IEC. *ISO/IEC 27001:2022(E) – Information security, cybersecurity and privacy protection — Information security management systems — Requirements*. 2022, pp. iv–v.

[3]UNI. *UNI/CT 001/GL 03 "Sistemi di gestione: HS, gestione del rischio e altri aspetti applicativi"*. 2023.

2. Riferimenti normativi
3. Termini e definizioni
4. Contesto dell'organizzazione
5. Leadership
6. Pianificazione
7. Supporto
8. Attività operative
9. Valutazione delle prestazioni
10. Miglioramento

Inoltre, si fonda sul principio del miglioramento continuo, attuato attraverso il ciclo PDCA (Plan, Do, Check, Act), che guida in modo sistematico la pianificazione, l'implementazione, la verifica e il perfezionamento dei processi di gestione della sicurezza delle informazioni[4].

A corredo del contenuto dello standard, l'*Annex A* riporta un catalogo di controlli di sicurezza selezionabili dalle aziende in base al proprio profilo di rischio[5], adattando così le misure alle necessità di ogni SGSI.

3.1.2 Misure di gestione del rischio informatico

La gestione del rischio costituisce l'elemento fondante di ISO 27001. Lo standard richiede infatti che l'organizzazione sia dotata di un processo strutturato per identificare, valutare e trattare i rischi per la sicurezza delle informazioni, in coerenza con il proprio contesto e con gli obiettivi strategici[6].

Il processo di gestione del rischio si articola in due fasi principali. La prima è la valutazione del rischio (*risk assessment*), che comprende l'identificazione delle minacce

[4]Watkins. *ISO/IEC 27001:2022: An introduction to information security and the SGSI standard*. IT Governance Publishing. 2022, p. 17.

[5]ISO/IEC. *ISO/IEC 27001:2022(E) – Information security, cybersecurity and privacy protection — Information security management systems — Requirements*. 2022, Annex A.

[6]ISO/IEC. *ISO/IEC 27001:2022(E) – Information security, cybersecurity and privacy protection — Information security management systems — Requirements*. 2022, pp. 6–8.

e delle vulnerabilità, l'analisi delle probabilità e degli impatti di potenziali incidenti ai danni dell'azienda e la determinazione dei livelli di rischio accettabili. La seconda è il trattamento del rischio (*risk treatment*), in cui l'organizzazione definisce e implementa misure tecniche e procedurali per ridurre i rischi a un livello ritenuto tollerabile[7]. Tale livello non è stabilito dallo standard, ma deve essere determinato dalle singole imprese in relazione alla loro esposizione alle minacce e alla capacità di tollerare il rischio, secondo il risk framework da loro adottato.

A completamento del processo, lo standard stabilisce che i risultati della gestione del rischio debbano essere documentati e integrati nei processi di governance e di pianificazione strategica. La responsabilità ultima della valutazione e accettazione dei rischi spetta alla direzione, la quale deve dimostrare un impegno attivo nella supervisione del sistema di gestione della sicurezza delle informazioni[8].

3.1.3 Controlli di sicurezza: Annex A

L'*Annex A* rappresenta il principale strumento operativo a supporto del trattamento del rischio: raccoglie un insieme di controlli di sicurezza che le organizzazioni possono adottare come misure di trattamento dei rischi individuati nei processi di valutazione[9]. Ogni controllo è formulato come un obiettivo da perseguire, lasciando all'organizzazione la libertà di definire le modalità più adeguate di implementazione in base al proprio contesto[10].

I controlli elencati sono 93 e sono organizzati in quattro domini tematici principali[11]:

1. Controlli organizzativi: includono politiche di sicurezza, responsabilità, relazioni con fornitori, gestione dei progetti e continuità operativa.

2. Controlli per le persone: comprendono la consapevolezza del personale, la formazione e la definizione dei ruoli di sicurezza.

[7]ISO/IEC. *ISO/IEC 27001:2022(E) – Information security, cybersecurity and privacy protection — Information security management systems — Requirements*. 2022, pp. 4–5.
[8]ISO/IEC. *ISO/IEC 27001:2022(E) – Information security, cybersecurity and privacy protection — Information security management systems — Requirements*. 2022, pp. 5–6.
[9]ISO/IEC. *ISO/IEC 27001:2022(E) – Information security, cybersecurity and privacy protection — Information security management systems — Requirements*. 2022, pp. iv–v.
[10]Watkins. *ISO/IEC 27001:2022: An introduction to information security and the SGSI standard*. IT Governance Publishing. 2022, p. 16.
[11]Watkins. *ISO/IEC 27001:2022: An introduction to information security and the SGSI standard*. IT Governance Publishing. 2022, pp. 28–29.

3. Controlli fisici: riguardano la protezione degli asset fisici, delle infrastrutture e degli ambienti di lavoro.

4. Controlli tecnologici: coprono ambiti come la gestione degli accessi, la protezione dei dati, il monitoraggio e la crittografia.

L'*Annex A*, pur non essendo esaustivo o prescrittivo, rappresenta un punto di riferimento comune per la progettazione delle misure di sicurezza. La sua funzione è quella di fornire un repertorio di *best practices* utilizzate e riconosciute a livello internazionale che possono essere selezionate, adattate o integrate in funzione delle necessità specifiche dell'impresa. Questo elemento rappresenta uno dei punti di forza di ISO, poiché permette alle imprese di calibrare le proprie politiche di sicurezza sulla base del profilo di rischio specifico del SGSI[12].

I controlli diventano anche parte integrante dello *Statement of Applicability* (SoA), il principale documento obbligatorio per la certificazione ISO che esplicita le misure adottate e ne giustifica l'esclusione ove non pertinenti[13].

3.1.4 Implicazioni organizzative della certificazione ISO 27001

L'adozione di ISO 27001 incide profondamente sulla governance, sui processi aziendali e sull'organizzazione in generale. Lo standard richiede il coinvolgimento attivo della direzione nella definizione della politica di sicurezza, nell'allocazione delle risorse e nella supervisione del SGSI, in conformità con le clausole 5.1 e 5.2[14]. L'adesione alla struttura armonizzata *Annex SL* rafforza questa centralità, rendendo la sicurezza parte integrante del governo aziendale e facilitandone l'integrazione con gli altri sistemi di gestione[15].

Dal punto di vista dei processi, la certificazione implica l'adozione di meccanismi di valutazione delle prestazioni, audit e riesame della direzione (clausole 9.1–9.3), che costituiscono un feedback periodico sull'efficacia delle misure di sicurezza e i rischi da

[12]Watkins. *ISO/IEC 27001:2022: An introduction to information security and the SGSI standard*. IT Governance Publishing. 2022, p. 22.

[13]ISO/IEC. *ISO/IEC 27001:2022(E) – Information security, cybersecurity and privacy protection — Information security management systems — Requirements*. 2022, pp. 4–5.

[14]ISO/IEC. *ISO/IEC 27001:2022(E) – Information security, cybersecurity and privacy protection — Information security management systems — Requirements*. 2022, pp. 2–3.

[15]UNI. *UNI/CT 001/GL 03 "Sistemi di gestione: HS, gestione del rischio e altri aspetti applicativi"*. 2023.

monitorare[16][17]. Tali attività sono strumenti chiave per rafforzare anche l'accountability e il monitoraggio da parte del management.

La Dichiarazione di Applicabilità (SoA) costituisce un documento cruciale di trasparenza gestionale: collega i rischi individuati con i controlli adottati (o esclusi, motivatamente), rendendo possibile al top management e agli auditor verificare la coerenza della strategia di sicurezza[18]. In questo senso, l'*Annex A* non rappresenta un insieme prescrittivo, ma un repertorio di misure da selezionare in base al profilo di rischio aziendale, responsabilizzando il top management nella definizione delle priorità per il SGSI da certificare[19].

La certificazione impone anche requisiti in materia di competenze, consapevolezza e comunicazione (clausole 7.2–7.4), che richiedono programmi di formazione, definizione chiara dei ruoli e processi di comunicazione interna ed esterna sulla sicurezza[20]. Questo favorisce lo sviluppo di una cultura aziendale della sicurezza, base della promozione di buone pratiche di igiene informatica.

Un ulteriore aspetto riguarda il miglioramento continuo (clausola 10), che formalizza la necessità di adattare politiche e controlli a nuove minacce e cambiamenti di contesto[21]. Qui ISO sottolinea l'importanza di ripetere periodicamente i processi di esame dei rischi e delle minacce, e di pianificazione delle misure necessarie, suggerendo quindi un ciclo di sicurezza aziendale, pur senza formalizzarlo.

ISO 27001 diventa così una leva manageriale per rendere tracciabili le decisioni sulla sicurezza, aumentare la fiducia degli stakeholder e sostenere la reputazione aziendale[22], oltre a fornire una metodologia strutturata per affrontare le minacce cyber. In prospettiva, la combinazione tra standardizzazione, audit e reporting facilita anche la dimostrazione di

[16]ISO/IEC. *ISO/IEC 27001:2022(E) – Information security, cybersecurity and privacy protection — Information security management systems — Requirements*. 2022, pp. 8–9.

[17]McIntosh, Susnjak, Liu, Watters, Xu, Liu, Nowrozy e Halgamuge. *From COBIT to ISO 42001: Evaluating cybersecurity frameworks for opportunities, risks, and regulatory compliance in commercializing large language models*. Elsevier Ltd. 2024, p. 2.

[18]ISO/IEC. *ISO/IEC 27001:2022(E) – Information security, cybersecurity and privacy protection — Information security management systems — Requirements*. 2022, pp. 4–5.

[19]Watkins. *ISO/IEC 27001:2022: An introduction to information security and the SGSI standard*. IT Governance Publishing. 2022, pp. 15–16.

[20]ISO/IEC. *ISO/IEC 27001:2022(E) – Information security, cybersecurity and privacy protection — Information security management systems — Requirements*. 2022, p. 6.

[21]ISO/IEC. *ISO/IEC 27001:2022(E) – Information security, cybersecurity and privacy protection — Information security management systems — Requirements*. 2022, p. 10.

[22]Watkins. *ISO/IEC 27001:2022: An introduction to information security and the SGSI standard*. IT Governance Publishing. 2022, p. 7.

adempimento rispetto agli obblighi normativi, ben integrandosi con la Direttiva NIS2[23][24].

3.2 NIST Cybersecurity Framework 2.0

3.2.1 Scopi e struttura del framework

Il *NIST Cybersecurity Framework* (CSF), a cura del *National Institute of Standards and Technology* (NIST), nasce nel 2014 con l'obiettivo di migliorare la protezione delle infrastrutture critiche negli Stati Uniti. La nuova versione 2.0, pubblicata nel febbraio 2024, amplia la portata del framework, rendendolo uno strumento utilizzabile a livello internazionale e per organizzazioni di ogni dimensione e settore[25]. Il NIST CSF, come l'ISO 27001, è uno dei framework di cybersicurezza più diffusi a livello globale, grazie alla sua capacità di adattamento a diversi settori e alla funzione di ponte tra aspetti tecnici e manageriali[26].

La struttura del CSF si articola in tre componenti principali:

- **Core**, il nucleo del framework, che raccoglie un insieme di *outcome* organizzati in Funzioni, Categorie e Sottocategorie. In particolare, sono individuate sei funzioni principali: *Govern*, *Identify*, *Protect*, *Detect*, *Respond*, *Recover*[27] (Fig. 3.1).

- **Organizational Profiles**, che descrivono lo stato attuale e quello target del posizionamento di sicurezza di un'organizzazione, consentendo di confrontare i gap e pianificare il miglioramento[28].

- **Tiers**, che rappresentano i livelli di maturità nella gestione del rischio, utili per valutare la capacità dell'organizzazione di integrare la cybersecurity nei processi decisionali e culturali[29].

[23]Moulinos, Theocharidou e ENISA. *Implementing Guidance on Commission Implementing Regulation (EU) 2024/2690 of 17.10.2024 laying down rules for the application of Directive (EU) 2022/2555 as regards technical and methodological requirements of cybersecurity risk-management measures.* 2024.
[24]Clusit. *Rapporto Clusit sulla Cybersecurity in Italia e nel mondo.* 2025.
[25]NIST. *The NIST Cybersecurity Framework (CSF) 2.0.* 2024, p. 1.
[26]McIntosh, Susnjak, Liu, Watters, Xu, Liu, Nowrozy e Halgamuge. *From COBIT to ISO 42001: Evaluating cybersecurity frameworks for opportunities, risks, and regulatory compliance in commercializing large language models.* Elsevier Ltd. 2024, p. 1.
[27]NIST. *The NIST Cybersecurity Framework (CSF) 2.0.* 2024, p. 5.
[28]NIST. *The NIST Cybersecurity Framework (CSF) 2.0.* 2024, p. 6.
[29]NIST. *The NIST Cybersecurity Framework (CSF) 2.0.* 2024, p. 7.

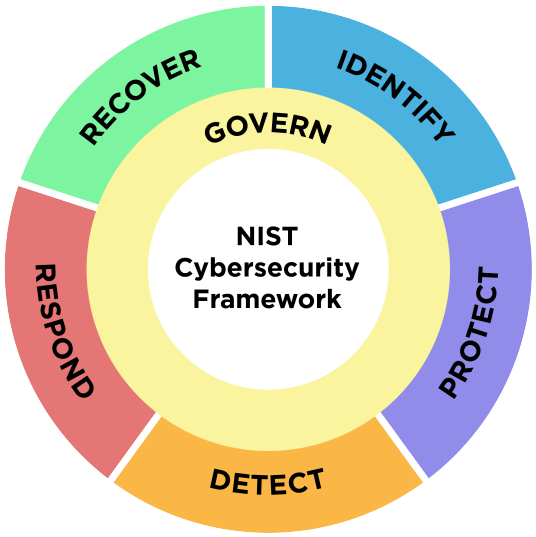


Figura 3.1: Funzioni del framework NIST CSF 2.0[30]

Lo scopo principale del CSF è fornire un modello flessibile che consenta alle imprese di gestire i rischi informatici in modo sistematico e integrato con gli altri rischi caratteristici del business[31]. Un'organizzazione può infatti utilizzare gli elementi Core, Profiles e Tiers per[32]:

- descrivere la postura di cybersicurezza attuale o target di una parte o dell'intera organizzazione, determinare i gap e valutare i progressi nel loro superamento;
- identificare, organizzare e dare priorità alle azioni per la gestione dei rischi di cybersicurezza in modo coerente con la missione dell'organizzazione, i requisiti legali e regolamentari, nonché le aspettative di gestione del rischio e di governance;
- fornire un linguaggio comune per comunicare, all'interno e all'esterno dell'organizzazione, in merito a rischi di cybersicurezza, capacità, esigenze ed aspettative.

Inoltre, il CSF 2.0 rafforza l'attenzione alla supply chain, riconosciuta come uno dei vettori di rischio più critici nello scenario contemporaneo[33], suggerendo una metodologia strutturata per la comunicazione in ambito di *Third Party Risk Management*.

[31]NIST. *The NIST Cybersecurity Framework (CSF) 2.0.* 2024, p. 2.
[32]NIST. *The NIST Cybersecurity Framework (CSF) 2.0.* 2024, pp. 1–2.
[33]NIST. *The NIST Cybersecurity Framework (CSF) 2.0.* 2024.

Dunque, a differenza di ISO, che stabilisce requisiti certificabili per quanto concerne la creazione, la documentazione e il mantenimento di un Sistema di Gestione per la Sicurezza delle Informazioni, il NIST CSF adotta un approccio più ampio, definendo misure di sicurezza sulla base di *outcome* desiderati[34] per quanto concerne tutti gli aspetti della cybersicurezza aziendale.

3.2.2 Approccio basato sul rischio e implementazione

La gestione del rischio si articola attraverso il CSF Core, che raccoglie sei funzioni principali: *Govern*, aggiunta nella versione 2.0 del CSF, *Identify*, *Protect*, *Detect*, *Respond* e *Recover*[35] (Fig. 3.1). Esse sono organizzate in categorie e sottocategorie, contenute nell'Appendice A del framework, che traducono gli obiettivi generali delle funzioni in risultati precisi e misurabili, che le aziende implementano mediante controlli di sicurezza.

- *Govern* enfatizza la necessità di collegare la cybersecurity alla governance aziendale, integrando la gestione del rischio informatico con la strategia complessiva dell'impresa[36].
- *Identify* si concentra sulla conoscenza del contesto organizzativo, degli asset critici e delle dipendenze, al fine di valutare correttamente le minacce.
- *Protect* è invece orientata all'implementazione di misure preventive, come il controllo degli accessi, la protezione dei dati e la formazione del personale.
- *Detect* ha lo scopo di sviluppare capacità di monitoraggio e di individuazione tempestiva di eventi e anomalie di sicurezza.
- *Respond* definisce le modalità di gestione degli incidenti, dalla comunicazione alla mitigazione.
- *Recover* garantisce il ripristino delle capacità operative e l'attivazione di meccanismi di miglioramento post-incidente, rafforzando la resilienza organizzativa.

Accanto al Core, il framework prevede due strumenti fondamentali di implementazione: i *Profiles* e gli *Implementation Tiers*. I *Profiles* descrivono lo stato attuale e lo stato target

[34]NIST. *The NIST Cybersecurity Framework (CSF) 2.0.* 2024, pp. 3–4.
[35]NIST. *The NIST Cybersecurity Framework (CSF) 2.0.* 2024, p. 5.
[36]NIST. *The NIST Cybersecurity Framework (CSF) 2.0.* 2024, p. 8.

della postura di sicurezza di un'organizzazione, consentendo di individuare le carenze nei confronti dell'obiettivo desiderato e pianificare un percorso di miglioramento[37]. I *Tiers*, articolati in quattro livelli (dal *Partial* all'*Adaptive*), rappresentano invece la maturità dei processi di gestione del rischio e la capacità di integrazione della cybersecurity nei processi decisionali e culturali. Pur non essendo certificativi, rappresentano validi strumenti di autovalutazione per l'azienda[38].

L'implementazione pratica del CSF attraversa ciclicamente cinque fasi:

1. comprensione del contesto e della missione aziendale;

2. definizione dei profili e analisi dei gap;

3. prioritizzazione degli interventi sulla base del rischio e delle risorse disponibili;

4. applicazione delle misure individuate;

5. monitoraggio e revisione continua.

Dunque, come avviene con il modello PDCA tipico degli standard ISO, il processo mantiene una logica di miglioramento continuo, volta ad adattare le misure a minacce e tecnologie in evoluzione.

Il *NIST Cybersecurity Framework*, nonostante la non certificabilità a differenza di ISO, è oggi ampiamente diffuso a livello globale grazie alla sua capacità di fungere da punto di raccordo tra aspetti tecnici e manageriali[39]. Un altro punto di forza risiede nella flessibilità: i vari documenti di supporto pubblicati dal NIST per l'implementazione del framework vengono aggiornati con regolarità, consentendo di adeguare le misure di sicurezza all'evoluzione delle minacce e del contesto tecnologico. Parmar e Miles ne sottolineano la crescente rilevanza in ambito europeo, dove è sempre più utilizzato come riferimento di *best practice* e come base per la mappatura con la Direttiva NIS2[40].

[37]NIST. *The NIST Cybersecurity Framework (CSF) 2.0*. 2024, p. 6.
[38]NIST. *The NIST Cybersecurity Framework (CSF) 2.0*. 2024, p. 7.
[39]McIntosh, Susnjak, Liu, Watters, Xu, Liu, Nowrozy e Halgamuge. *From COBIT to ISO 42001: Evaluating cybersecurity frameworks for opportunities, risks, and regulatory compliance in commercializing large language models*. Elsevier Ltd. 2024, p. 3.
[40]Parmar e Miles. *Cyber Security Frameworks (CSFs): An Assessment Between the NIST CSF v2.0 and EU Standards*. IEEE. 2024, p. 12.

3.2.3 Implicazioni organizzative dell'adozione del NIST CSF 2.0

Dal punto di vista organizzativo, il NIST CSF definisce un processo di gestione e trattamento del rischio ciclico. Matteo Herin osserva come le funzioni del framework siano rappresentate secondo un cerchio, alla cui base si colloca la funzione di governo e intorno alla quale si susseguono le altre. Il primo step è rappresentato dall'identificazione delle minacce, per poi procedere con l'implementazione delle protezioni necessarie. Le funzioni successive entrano in gioco in caso di attacco, con il monitoraggio attivo e la risposta a eventuali attacchi tramite i playbook codificati per contenere ed estirpare l'ostilità. Infine, avviene il recupero dall'incidente con il ripristino delle normali funzioni, per poi ricominciare il ciclo dalla funzione *Identify* sulla base della *lesson learned* ricavata dall'analisi degli eventi.

Un'attenzione particolare deve essere rivolta alla funzione *Govern*, i cui obiettivi risultano coerenti con le priorità individuate dagli enti europei[41]. Essa evidenzia la necessità di un coinvolgimento esplicito della direzione nella definizione delle strategie di sicurezza, nella distribuzione delle responsabilità e nella supervisione dei processi di gestione del rischio[42]. In questo senso, il CSF si propone come strumento per rafforzare il legame tra obiettivi strategici e misure operative, rendendo la sicurezza informatica parte integrante della strategia aziendale.

L'utilizzo dei *Profiles* e dei *Tiers* consente al management di valutare lo stato di maturità della propria postura di sicurezza e di stabilire priorità di investimento. Ciò fornisce ai CISO uno strumento di dialogo con il vertice aziendale, facilitando la traduzione dei rischi tecnici in rischi di business e la pianificazione di roadmap di progresso[43]. Il framework diventa così anche un mezzo di comunicazione strategica, utile a colmare il divario tra linguaggio tecnico e decisioni manageriali, rendendo più efficace e diretta la comunicazione in materia di cybersicurezza.

L'adozione del CSF stimola inoltre la diffusione di una cultura organizzativa del rischio, favorendo la sensibilizzazione del personale, l'assegnazione di ruoli chiari e la creazione di processi di feedback continui. La sua implementazione rafforza la resilienza aziendale e contribuisce alla dimostrazione di *due diligence*, aspetto particolarmente rilevante in

[41] ENISA. *Enisa Threat Landscape 2024*. 2024, Allegato B.
[42] NIST. *The NIST Cybersecurity Framework (CSF) 2.0*. 2024, Appendice A.
[43] Parmar e Miles. *Cyber Security Frameworks (CSFs): An Assessment Between the NIST CSF v2.0 and EU Standards*. IEEE. 2024.

un contesto regolatorio come quello della Direttiva NIS2, che richiede alle organizzazioni di integrare la cybersecurity nella propria struttura di governance[44]. Il framework si configura dunque come un supporto essenziale per l'IT Manager, chiamato a guidare l'implementazione delle linee guida NIST attraverso misure concrete.

[44]ENISA. *Enisa Threat Landscape 2024*. 2024, pp. 110–115.

Capitolo 4

Analisi comparativa tra standard internazionali per l'adempimento di NIS2

4.1 Introduzione al confronto

4.1.1 ISO 27001, NIST CSF 2.0 e NIS2

In questo capitolo dell'elaborato si svolge un confronto tra i framework presentati, ISO 27001 e NIST CSF 2.0, e la Direttiva NIS2, con l'obiettivo di comprendere quale ruolo essi possano avere nel soddisfare i requisiti stabiliti dal legislatore europeo.

L'analisi comparativa si basa sul confronto tra gli articoli NIS2 dal 20 al 25, le misure stabilite da ISO 27001 e le funzioni e i controlli del NIST CSF 2.0. Il NIST CSF 2.0 e ISO 27001 presentano numerosi obiettivi comuni, ma possiedono differenze significative nella struttura e nell'approccio adottati. Come evidenziato nella prassi di riferimento UNI/PdR 174, ISO 27001 ha un'impostazione sistemica ed è strutturata a requisiti, in modo da consentire all'organizzazione la certificazione accreditata di un proprio SGSI. Il NIST CSF 2.0, invece, rappresenta uno strumento per valutare e potenziare il proprio profilo di cybersicurezza in relazione al rischio cui si è esposti. Di conseguenza, non tutti i controlli di ISO trovano una corrispondenza in NIST CSF 2.0 e viceversa[1]. Tali divergenze emergono anche nel confronto con la Direttiva NIS2.

[1]UNI. *UNI/PdR 174:2025*. 2025.

4.1.2 Framework di cybersicurezza nazionali

Un ruolo importante nell'adozione di NIS2 è ricoperto dai framework per la cybersicurezza varati dagli Stati membri a livello nazionale. Le direttive europee, come visto, necessitano di un recepimento nazionale per entrare in vigore e i singoli organi di governo in tale fase possono introdurre ulteriori specifiche e modifiche alle misure stilate dall'Unione. In questo modo, si ottengono molteplici derivazioni nazionali di NIS2, ognuna delle quali interpreta e rafforza la normativa in maniera leggermente differente[2], il che costringe le imprese multinazionali ad adattare le proprie procedure per soddisfare i requisiti specifici per più nazioni[3].

In questo contesto, è interessante notare come gli Stati membri incorporano gli standard internazionali come NIST e ISO nel recepimento di NIS2, creando così framework nazionali ibridi. Un approccio degno di nota è quello del Belgio, in cui la certificazione ISO 27001 è considerata equivalente a soddisfare gli standard NIS2[4]. Altri Paesi, invece, hanno sviluppato i propri framework nazionali a partire da quelli ISO e NIST. Tra essi vi è l'Italia, che ha creato il *Framework Nazionale per la Cybersecurity e la Data Protection* sulla base dell'adattamento del NIST CSF al contesto locale.

Il riconoscimento di framework esistenti come equivalenti a NIS2 rappresenta una misura a grandissimo vantaggio delle aziende. Viste le numerose sfide nell'implementazione di NIS2, esaminate nel Capitolo 2, ciò porterebbe ad una considerevole riduzione degli sforzi richiesti alle imprese, a vantaggio delle aziende più piccole e di chi già ha operato investimenti strategici in standard specifici[5]. Tuttavia è necessario riflettere sugli effetti a lungo e breve termine di una misura di questo tipo. Infatti, se l'impatto sulle risorse aziendali nel breve termine è sicuramente positivo, sul lungo periodo si individuano due potenziali rischi:

- Lasciare agli Stati membri l'onere di stabilire quale framework riconoscere come valido porterebbe a un'ulteriore frammentazione delle metodologie di cybersicurezza aziendali, vanificando l'obiettivo di unificazione alla base di NIS2.

[2]Parmar e Miles. *Cyber Security Frameworks (CSFs): An Assessment Between the NIST CSF v2.0 and EU Standards*. IEEE. 2024, p. 5.
[3]ECSO. *ECSO White Paper — NIS2 Implementation: Challenges & Priorities*. 2025, p. 18.
[4]ECSO. *ECSO White Paper — NIS2 Implementation: Challenges & Priorities*. 2025, p. 4.
[5]ECSO. *ECSO White Paper — NIS2 Implementation: Challenges & Priorities*. 2025, p. 8.

- Stabilire in maniera univoca un framework come equivalente a NIS2 porterebbe da un lato alla creazione di un monopolio di un unico ente certificatore e dall'altro all'accantonamento di NIS2, rendendola di fatto superflua.

Una strada percorribile potrebbe essere rappresentata dalla scelta di alcuni standard temporaneamente equivalenti a NIS2, in modo da favorire le imprese che già li adottano e ridurre l'impatto sulle risorse per l'implementazione delle misure di sicurezza, nell'ottica di un progressivo adattamento ai requisiti NIS2. Ciò necessita della creazione di strumenti di mappatura dedicati tra gli standard e NIS2[6], iniziativa a cui questo capitolo ambisce a contribuire.

Un'altra soluzione di natura opposta è rappresentata dalla creazione di un unico framework di cybersicurezza europeo, proseguendo quindi nella direzione tracciata dal legislatore con NIS2, corredato da framework per la gestione del rischio e della sicurezza della *supply chain*, con l'obiettivo di ridurre al minimo la frammentazione[7][8] e di accorpare in esso le disposizioni derivanti anche da altre normative rilevanti, quali GDPR e DORA.

4.1.3 Tabella comparativa

In questo capitolo il confronto è condotto con un'impostazione teorico–argomentativa: si chiariscono criteri, affinità e differenze tra NIS2, ISO/IEC 27001 e NIST CSF 2.0. A supporto e verifica di tale analisi, nel Capitolo 5 è riportata una tabella di mappatura che delinea l'allineamento delle misure prescritte dall'Art. 21 della Direttiva NIS2 con gli obiettivi esposti nell'allegato del framework NIST e i controlli dell'*Annex A* di ISO 27001. La tabella traduce quanto discusso di seguito in evidenze implementative, consentendo di leggere sia il posizionamento dei singoli standard rispetto a NIS2 sia il potenziale effetto combinato nel percorso di attuazione.

[6]ECSO. *ECSO White Paper — NIS2 Implementation: Challenges & Priorities*. 2025, pp. 7–9.
[7]Parmar e Miles. *Cyber Security Frameworks (CSFs): An Assessment Between the NIST CSF v2.0 and EU Standards*. IEEE. 2024, pp. 4–6.
[8]ECSO. *ECSO White Paper — NIS2 Implementation: Challenges & Priorities*. 2025, pp. 7–9.

4.2 Allineamento di ISO 27001 con NIS2

4.2.1 Convergenze

La certificazione ISO 27001 è, come detto, tra le più adottate dalle aziende, con più di 40.000 certificazioni rilasciate a livello mondiale[9]. Essa garantisce evidenti vantaggi alle aziende rispetto agli adempimenti richiesti da NIS2, fornendo una solida struttura per la governance della cybersicurezza dell'azienda e l'adozione di controlli di sicurezza sui sistemi informatici[10].

Un primo elemento di convergenza tra la Direttiva NIS2 e lo standard ISO/IEC 27001:2022 riguarda la centralità della governance e del ruolo del top management. ISO impone alla direzione aziendale obblighi espliciti in materia di leadership, definizione delle policy e attribuzione di ruoli e responsabilità (clausole 5.1–5.3), che trovano un diretto parallelo in NIS2[11], dove la responsabilità ultima della sicurezza informatica è attribuita agli organi societari. Questo aspetto rende lo standard utile a strutturare la governance dell'azienda, fornendo un'organizzazione dettagliata, producendo documentazione utile a certificare l'adozione di misure di cybersicurezza e facilitando l'accountability anche in ambito NIS2[12][13], come sostenuto anche dai CISO intervistati.

Un secondo punto riguarda l'approccio alla gestione del rischio. ISO 27001 prevede un processo strutturato di valutazione e trattamento del rischio (clausole 6.1.2–6.1.3), ciclicamente riesaminato e aggiornato. Tale approccio è coerente con l'impostazione *risk-based* di NIS2, che richiede analisi periodiche delle minacce e adeguamento delle misure di sicurezza[14]. La prassi UNI/PdR 174 sottolinea come l'adozione di ISO permetta di armonizzare le attività di *risk assessment* con i requisiti operativi derivanti da NIS2[15], costruendo una base per le attività di cybersicurezza fortemente improntata all'individuazione, alla valutazione e alla gestione del rischio.

[9] McIntosh, Susnjak, Liu, Watters, Xu, Liu, Nowrozy e Halgamuge. *From COBIT to ISO 42001: Evaluating cybersecurity frameworks for opportunities, risks, and regulatory compliance in commercializing large language models*. Elsevier Ltd. 2024, p. 2.

[10] ECSO. *ECSO White Paper — NIS2 Implementation: Challenges & Priorities*. 2025, p. 35.

[11] Unione Europea. *Direttiva (UE) 2022/2555 del Parlamento Europeo e del Consiglio del 14 dicembre 2022 relativa a misure per un livello comune elevato di cibersicurezza nell'Unione (NIS 2)*, artt. 20–21.

[12] Kouns e Kouns. *The CISO Perspective: Understand the importance of the CISO in the cyber threat landscape*. IT Governance Publishing. 2023, pp. 56–58.

[13] ECSO. *ECSO White Paper — NIS2 Implementation: Challenges & Priorities*. 2025, p. 35.

[14] Unione Europea. *Direttiva (UE) 2022/2555 del Parlamento Europeo e del Consiglio del 14 dicembre 2022 relativa a misure per un livello comune elevato di cibersicurezza nell'Unione (NIS 2)*, art. 21(2).

[15] UNI. *UNI/PdR 174:2025*. 2025, p. 9.

Inoltre, i controlli operativi di ISO coprono altre aree chiave previste dalla direttiva. Le misure sulla gestione degli incidenti (A.5.24–A.5.28), il monitoraggio continuo (A.8.16) e le pratiche di *threat intelligence* (A.5.07) trovano corrispondenza con le prescrizioni NIS2 sulla rilevazione, risposta e notifica degli incidenti. Anche le misure di continuità e ripristino (A.5.29–A.5.30, A.8.13–A.8.14) sono in linea con gli obblighi di *business continuity* e *disaster recovery* richiesti dalla direttiva[16].

Le convergenze non si limitano agli aspetti tecnici, ma si estendono anche alla cultura organizzativa. ISO 27001 valorizza la formazione del personale (A.6.3) e la consapevolezza in materia di sicurezza, aspetti richiamati anche da NIS2 che introduce obblighi di istruzione e informazione, oltre che di responsabilità.

Infine, i CISO intervistati spiegano come la motivazione principale per cui le aziende decidono di adottare ISO rimanga la certificabilità delle misure. In questo modo, l'azienda dispone da un lato di un SGSI chiaro e ben strutturato e dall'altro di un valido strumento di accountability, ossia il certificato e tutti i documenti di monitoraggio che ISO richiede. Questo permette di dimostrare, laddove un auditor esterno o il regolatore necessitino di verificare la conformità dell'azienda ai requisiti, la bontà del sistema di gestione della sicurezza oggetto del controllo.

4.2.2 Divergenze

Pur essendo spesso reputata un punto di partenza essenziale per la compliance NIS2, il CISO di Prometeia precisa che la certificazione ISO 27001 non è completamente sovrapponibile alla direttiva.

In primo luogo, ISO non si applica ai sistemi dell'azienda in maniera integrata, ma il suo perimetro è rappresentato da un singolo SGSI. L'azienda, spiega il CISO di Carrefour Italia, può decidere in seguito di certificare tutti i suoi SGSI oppure, come spesso avviene, solamente quelli considerati più critici in relazione al profilo di rischio. Al contrario, NIS2 interessa tutta l'azienda e i suoi sistemi di sicurezza per intero, essendo l'applicabilità non volontaria, ma stabilita dal legislatore in base alla classificazione del soggetto come *essenziale* o *importante*. Verosimilmente, dunque, molte aziende che adottano ISO solo sui sistemi critici devono integrare misure ulteriori anche in aree che non dispongono di

[16]ECSO. *ECSO White Paper — NIS2 Implementation: Challenges & Priorities*. 2025, p. 5.

controlli informatici sufficienti.

Un tema importante della certificazione ISO, evidenziato dai CISO intervistati, è il fatto che ISO consenta di certificare misure di sicurezza, ma non garantisca l'efficacia sostanziale dei controlli in ottica NIS2. ISO infatti adotta un approccio basato sul rischio, che lascia all'organizzazione la scelta dei controlli più adeguati in base al livello di rischio che l'azienda stessa ha ritenuto accettabile in relazione alle procedure di *risk assessment* svolte. NIS2, al contrario, introduce istanze più prescrittive, rendendo di fatto obbligatorie alcune misure – salvo motivata giustificazione. L'obiettivo di NIS2 è infatti quello di fornire alle imprese delle misure minime di resilienza, ritenute indispensabili in relazione al livello di rischio dell'organizzazione all'interno del sistema Paese, richiedendo, come spiega Herin, una valutazione del rischio improntata su aspetti più concreti e non strettamente formali. In questo senso, NIS2 ha un obiettivo più ampio e più operativo, imponendo la necessità di testare periodicamente l'efficacia dei *playbook* e delle misure di contrasto alle minacce, mentre ISO si concentra principalmente sull'adozione formale dei controlli senza preoccuparsi dell'efficacia degli stessi in fase di audit.

Un'altra divergenza dovuta alla natura regolatoria di NIS2 riguarda gli obblighi di notifica. ISO 27001 prevede processi di gestione degli incidenti e di reporting interno (A.5.24–A.5.28), i quali possono fornire da supporto, ma non impone scadenze stringenti né modalità di comunicazione verso autorità esterne. NIS2 stabilisce invece tempistiche tramite KPI precisi per l'informazione delle autorità competenti in caso di incidenti significativi[17]. Questo comporta per le aziende certificate ISO la necessità di integrare playbook e workflow dedicati per garantire la compliance normativa, integrando la documentazione e le procedure interne già implementate con ISO.

Si rileva anche una discostamento nella definizione delle responsabilità del top management. ISO si limita a richiedere leadership e impegni formali (clausole 5.1–5.3), mentre NIS2 introduce responsabilità dirette e, in alcuni casi, sanzioni personali a carico degli amministratori in caso di mancata adozione delle misure adeguate[18], richiedendo un coinvolgimento più attivo e sostanziale del management nella supervisione della cybersicurezza.

[17]Unione Europea. *Direttiva (UE) 2022/2555 del Parlamento Europeo e del Consiglio del 14 dicembre 2022 relativa a misure per un livello comune elevato di cibersicurezza nell'Unione (NIS 2)*, art. 23.

[18]Unione Europea. *Direttiva (UE) 2022/2555 del Parlamento Europeo e del Consiglio del 14 dicembre 2022 relativa a misure per un livello comune elevato di cibersicurezza nell'Unione (NIS 2)*, art. 20.

Infine, sia NIS2 che ISO/IEC 27001 pongono attenzione alla supply chain security, ma in modo differente. ISO fornisce strumenti per formalizzare controlli e verifiche lungo la catena del valore (A.5.19–A.5.20), mentre NIS2 rende questo obbligo cogente e sanzionabile, richiedendo ancora una volta controlli effettivi più stringenti, attribuendone la responsabilità a ogni soggetto NIS2[19].

4.2.3 Ruolo nell'implementazione di NIS2

Ai fini dell'adozione di NIS2, ISO 27001 si configura come uno strumento di governo manageriale, capace di introdurre responsabilità e accountability nella gestione della sicurezza informatica, aiutando le aziende a:

- creare un SGSI strutturato e manutenibile;
- disporre di obiettivi di controllo solidi;
- produrre documentazione per auditor esterni.

Lo standard abilita quindi le imprese a sviluppare capacità organizzative e processi di gestione del rischio verificabili, trovando numerose corrispondenze nella Direttiva NIS2, ma non coincide con la piena conformità normativa: per i CISO, rappresenta un abilitatore che necessita inevitabilmente di integrazioni da individuare tramite la conduzione di una *gap analysis* tra le misure implementate dall'azienda e gli obblighi di legge.

Il vantaggio principale che introduce ISO è la disponibilità di un certificato rilasciato da un auditor ISO che verifica l'impegno da parte dell'azienda nell'adozione di misure a tutela della sicurezza informatica. Tuttavia, ciò non dimostra la completa aderenza alla normativa: la certificazione ISO 27001 rappresenta un metodo per le aziende di dimostrare accountability laddove un auditor NIS2 richieda di verificare le misure in essere, ma si dimostra carente nel fissare un livello di sicurezza effettiva coerente con le richieste di NIS2. In particolare, spiegano i CISO interpellati, ISO 27001 certifica l'adozione di determinati strumenti di sicurezza e di documentazione da un punto di vista formale, mentre la vocazione di NIS2 è più operativa e richiede controlli sostanziali.

Infine, è necessario riflettere sul diverso obiettivo di NIS2 e ISO 27001. La capacità di ISO di fornire una struttura ben definita per la governance della cybersicurezza e

[19] Unione Europea. *Direttiva (UE) 2022/2555 del Parlamento Europeo e del Consiglio del 14 dicembre 2022 relativa a misure per un livello comune elevato di cibersicurezza nell'Unione (NIS 2)*, art. 21.

l'implementazione di controlli sui sistemi di gestione della sicurezza informatica è un punto di forza nella transizione verso NIS2. Tuttavia, la direttiva europea include obblighi più stringenti, come il controllo della *supply chain* e gli obblighi di notifica in caso di incidenti.

Michele Rivieri osserva inoltre la possibilità di integrare ISO 27001 con altri standard ISO, come il 27701 per la gestione delle informazioni sulla privacy e il 22301 per la gestione della *business continuity*, i quali contengono a loro volta elementi abilitanti alla compliance della direttiva. Secondo ENISA[20], invece, altri standard rilevanti sono:

- ISO 22313:2020 e ISO 22301:2019 per misure di continuità operativa;
- ISO 22361:2022 per controlli inerenti a sicurezza, resilienza e gestione delle crisi;
- ISO 21500:2020 e ISO 21500:2021 per la gestione di progetti, programmi e portfolio.

4.3 Allineamento del NIST CSF 2.0 con NIS2

4.3.1 Convergenze

Il NIST CSF 2.0 e NIS2 condividono una forte base contenutistica. Entrambi nascono, seppur in contesti differenti, con l'obiettivo di fornire linee guida minime per la cybersicurezza e la resilienza informatica e di contribuire allo sviluppo di un programma di cybersecurity nelle organizzazioni.

Una caratteristica comune tra NIST CSF e NIS2 è che entrambi richiedono artefatti attuativi. Il primo, infatti, è presentato come un insieme di *best practices* che necessitano di una creazione di un *action plan* dedicato. La seconda, invece, deve essere codificata in un framework di cybersicurezza a livello di ogni singolo Stato membro; sarà poi tale framework che le singole imprese utilizzeranno per derivare il proprio, adattandolo alle esigenze specifiche del contesto[21]. Alternativamente, le imprese possono implementare direttamente NIS2 nel proprio framework aziendale, ma con alcune implicazioni di cui si discute più avanti.

[20] Moulinos, Theocharidou e ENISA. *Implementing Guidance on Commission Implementing Regulation (EU) 2024/2690 of 17.10.2024 laying down rules for the application of Directive (EU) 2022/2555 as regards technical and methodological requirements of cybersecurity risk-management measures.* 2024.

[21] Parmar e Miles. *Cyber Security Frameworks (CSFs): An Assessment Between the NIST CSF v2.0 and EU Standards.* IEEE. 2024.

NIS2 e il NIST CSF riconoscono la governance come un costituente essenziale della strategia aziendale e della gestione della sicurezza informatica nelle organizzazioni. La gestione dei processi, della tecnologia e delle risorse umane è infatti un elemento fondante delle misure prescritte dalle due fonti. All'interno della funzione *Govern* del NIST CSF trovano corrispondenza gli obblighi fissati da NIS2 per quanto riguarda[22]:

- la creazione di una strategia di cybersicurezza uniforme, per favorire l'allineamento delle organizzazioni;
- la designazione di un punto di contatto all'interno delle organizzazioni, referente deputato alla gestione delle comunicazioni di cybersicurezza;
- la sicurezza della *supply chain*, tramite la regolazione e il monitoraggio delle interazioni con entità parte della catena del valore e la gestione degli incidenti che si possono verificare lungo essa.

Il ciclo delle funzioni del NIST CSF si svolge a partire dalla funzione *Identify*. Qui trovano spazio le misure relative alla gestione degli asset, l'identificazione delle vulnerabilità, il tracciamento delle informazioni di *threat intelligence*, necessarie all'adempimento della Direttiva NIS2[23].

Anche la funzione *Protect* mostra un allineamento con NIS2, stabilendo controlli di sicurezza nelle aree di protezione dei dati trasmessi, gestione delle identità digitali e specifici requisiti come l'autenticazione a due fattori e gli obblighi di formazione delle risorse umane nell'ambito cyber[24].

Per quanto riguarda le funzioni NIST inerenti alla protezione dalle minacce e al recupero da situazioni di crisi informatica, il CSF e NIS2 continuano a dimostrarsi coerenti. *Protect*, *Respond* e *Recover* forniscono misure che permettono all'organizzazione di strutturare una metodologia operativa per adempiere alle richieste del legislatore nei seguenti ambiti[25]:

[22]Parmar e Miles. *Cyber Security Frameworks (CSFs): An Assessment Between the NIST CSF v2.0 and EU Standards*. IEEE. 2024, p. 4.
[23]Parmar e Miles. *Cyber Security Frameworks (CSFs): An Assessment Between the NIST CSF v2.0 and EU Standards*. IEEE. 2024, p. 4.
[24]Parmar e Miles. *Cyber Security Frameworks (CSFs): An Assessment Between the NIST CSF v2.0 and EU Standards*. IEEE. 2024, p. 4.
[25]Parmar e Miles. *Cyber Security Frameworks (CSFs): An Assessment Between the NIST CSF v2.0 and EU Standards*. IEEE. 2024, p. 4.

- predisposizione al dialogo con il CSIRT nazionale e le autorità in caso di incidenti significativi o di eventi di sicurezza informatica;

- necessità di sviluppare un *Business Continuity Plan* (BCP) per codificare le procedure da adottare in caso di incidente garantendo le funzionalità minime necessarie all'operatività dell'azienda;

- necessità di sviluppare un *Disaster Recovery Plan* (DRP) per strutturare le operazioni per il ripristino della normale condizione di operatività in seguito a un incidente o un'interruzione grave dei servizi.

4.3.2 Divergenze

Nonostante i numerosi punti di contatto, NIS2 e il NIST CSF presentano anche elementi di divergenza.

Il NIST CSF 2.0 è un framework creato dal *National Institute of Standards and Technology* (NIST), istituzione parte del governo degli Stati Uniti d'America. Per questo motivo, è strutturato sulla base del contesto americano, ma la sua struttura si adatta bene alle organizzazioni di tutto il mondo[26]. Al contrario, NIS2 è una direttiva dell'Unione Europea, pensata per l'applicazione nel contesto europeo.

NIS2 pone infatti grande attenzione alla collaborazione a livello internazionale e alla condivisione di informazioni riguardanti gli eventi di sicurezza informatica. L'idea alla base di tali misure è figlia della volontà del legislatore europeo di creare una community di esperti cyber per favorire l'innovazione e il progresso della sicurezza nelle organizzazioni, anche al di là dei confini nazionali. Ciò si presta particolarmente all'ecosistema europeo, individuando la necessità di ridurre la frammentazione e creare un fronte internazionale comune contro le minacce informatiche, vocazione che invece non si evince esplicitamente dal NIST CSF 2.0[27]. Inoltre, data la sua natura regolatoria, NIS2 introduce un livello di specificità superiore per l'attuazione di determinate modalità operative rispetto a quanto avviene nel framework NIST. Si evidenzia infatti la presenza di precisi KPI (*Key Per-*

[26]Parmar e Miles. *Cyber Security Frameworks (CSFs): An Assessment Between the NIST CSF v2.0 and EU Standards*. IEEE. 2024, pp. 1–3.
[27]Parmar e Miles. *Cyber Security Frameworks (CSFs): An Assessment Between the NIST CSF v2.0 and EU Standards*. IEEE. 2024, p. 4.

formance Indicator) fissati dal regolatore UE per la definizione di soglie precise per la gestione e la notifica degli incidenti alle autorità[28], indicatori non previsti dal NIST.

Inoltre, le differenze strutturali riguardano anche la modalità con cui NIS2 e NIST CSF prescrivono le proprie misure. Mentre il NIST CSF è un framework volontario e perciò l'adesione alle misure presentate è lasciata alla discrezione delle aziende, NIS2 si configura come un insieme di obblighi a cui i soggetti interessati devono attenersi con rigore per dimostrare il proprio adempimento e non incorrere in sanzioni (non previste nel caso del NIST CSF)[29].

Un'ulteriore differenza fondamentale tra NIS2 e NIST CSF risiede nella modalità di implementazione. Seppur entrambi abbiano una vocazione fortemente operativa, superiore a ISO 27001, necessitano come visto di un ulteriore raffinamento per l'applicazione diretta. Perciò il NIST suggerisce lo sviluppo di un piano d'azione che stabilisca i KPI (non presenti nel framework) e gli indicatori di rischio utili alla valutazione delle misure da implementare sulla base delle vulnerabilità individuate. Al contrario, il processo di adozione di NIS2 può essere più complesso e rappresentare una sfida notevole, soprattutto per le organizzazioni con un livello di maturità dei sistemi di sicurezza inferiore. Per affrontare questo processo, può essere utile l'adozione di uno (o più) framework che forniscano una struttura solida su cui basare la strategia di sicurezza informatica[30].

Infine, i CISO ascoltati concordano nell'individuare limite del framework NIST nella mancanza di una forma di certificazione riconosciuta delle misure implementate. Ciò riduce la rilevanza del CSF, rispetto a ISO 27001, nel dimostrare accountability per le misure di sicurezza informatiche, spingendo le aziende ad adottare il NIST CSF solo parzialmente come strumento di supporto, data la grande coerenza con NIS2, ma senza la necessità di implementarlo nella sua interezza.

4.3.3 Ruolo nell'implementazione di NIS2

Viste le numerose analogie tra il framework NIST e NIS2 è evidente come il primo possa avere un ruolo fondamentale nell'adozione della direttiva. Similmente a quanto visto con

[28]Parmar e Miles. *Cyber Security Frameworks (CSFs): An Assessment Between the NIST CSF v2.0 and EU Standards*. IEEE. 2024, p. 5.
[29]Parmar e Miles. *Cyber Security Frameworks (CSFs): An Assessment Between the NIST CSF v2.0 and EU Standards*. IEEE. 2024, p. 4.
[30]Parmar e Miles. *Cyber Security Frameworks (CSFs): An Assessment Between the NIST CSF v2.0 and EU Standards*. IEEE. 2024.

ISO, il NIST CSF permette alle organizzazioni di strutturare la governance, i controlli e le procedure di sicurezza informatica, ottenendo una valida base da completare con gli adempimenti necessari stabiliti da NIS2. In quest'ottica, può rappresentare una soluzione utile per aziende con strutture di sicurezza informatica più acerbe, che necessitano di un approccio strutturato alle tematiche cyber, ma coadiuvato da integrazioni mirate.

Nella struttura del framework NIST Herin rileva una maggiore vocazione operativa, coerente con NIS2, rispetto allo standard ISO 27001. Nonostante il CSF sia presentato come ciclico, si osserva una divisione netta del framework in due parti:

1. le funzioni *Identify* e *Protect* definiscono la condizione della sicurezza informatica durante la normale condizione di operatività, costruite sulla funzione *Govern* che definisce la governance aziendale;

2. le funzioni *Detect*, *Respond* e *Recover* strutturano invece l'operatività aziendale all'avvenimento di un incidente di sicurezza e alla crisi che ne può derivare. Al raggiungimento dello step *lessons learned* il ciclo si ripete a partire da *Identify* per correggere il governo e le misure implementate sulla base delle analisi svolte sull'attacco subito e delle vulnerabilità individuate.

Analogamente, NIS2 definisce sia le misure da implementare in condizioni di normale operatività sia quelle per la gestione degli eventi di *security breach*. Secondo il CISO di Carrefour, da questo punto di vista l'approccio NIST è più in linea con NIS2 rispetto a ISO 27001, definendo un insieme di processi utili a gestire operativamente tutti gli scenari cyber in azienda.

Tuttavia, è necessario integrare tali processi con le richieste dell'Unione per quanto riguarda gli obblighi di notifica e relazione con le autorità, non individuati dal NIST. In questo processo, è fondamentale tenere conto degli indicatori di rischio richiesti da NIS2 per identificare quali misure siano da implementare in relazione al livello di rischio dell'azienda, nonché dei KPI utili in fase di gestione delle emergenze di sicurezza informatica.

Capitolo 5

Tabella di comparazione tra NIS2, ISO/IEC 27001:2022 e NIST CSF 2.0

In questo capitolo si espone una tabella riassuntiva del confronto tra la Direttiva NIS2 e gli standard internazionali di cybersicurezza presi in esame. Tale elaborato ha lo scopo di riassumere le considerazioni contenute nel Capitolo 4, fornendo una visione più sintetica e operativa, utile per la comprensione degli allineamenti e delle lacune tra la Direttiva, il framework NIST CSF 2.0 e lo standard ISO/IEC 27001:2022. In particolare, si mappano gli articoli della NIS2 con le corrispondenti misure previste negli obiettivi dell'allegato del framework NIST e nei controlli dell'*Annex A* dello standard ISO. Si segnala che le corrispondenze qui individuate sono di carattere riassuntivo e devono necessariamente essere relazionate alle considerazioni, più complete, riportate nel Capitolo 4.

La tabella è costruita tramite un confronto diretto tra l'articolo 21 della Direttiva NIS2 e le relative misure specificate nel Regolamento di esecuzione 2024/2690, lo standard ISO/IEC 27001:2022 e il framework NIST CSF 2.0. Sulla base dell'analisi condotta nel testo Konstantinos Moulinos, Marianthi Theocharidou e ENISA. *Implementing Guidance on Commission Implementing Regulation (EU) 2024/2690 of 17.10.2024 laying down rules for the application of Directive (EU) 2022/2555 as regards technical and methodological requirements of cybersecurity risk-management measures.* Rapp. tecn. Draft for Public Consultation. European Union Agency for Cybersecurity (ENISA), 2024.

A supporto del confronto sono stati analizzati contributi similari presenti nelle seguenti fonti:

- Manisha Parmar e Andy Miles. *Cyber Security Frameworks (CSFs): An Assessment*

Between the NIST CSF v2.0 and EU Standards. In: (2024);

- Marion Toussaint, Sylvère Krima e Hervé Panetto. *Industry 4.0 data security: A cybersecurity frameworks review*. In: *Journal of Industrial Information Integration* 39 (2024);
- Timothy R. McIntosh, Teo Susnjak, Tong Liu, Paul Watters, Dan Xu, Dongwei Liu, Raza Nowrozy e Malka N. Halgamuge. *From COBIT to ISO 42001: Evaluating cybersecurity frameworks for opportunities, risks, and regulatory compliance in commercializing large language models*. In: *Computers & Security* 144 (2024);
- UNI. *UNI/PdR 174:2025*. Sistema di gestione per la cybersicurezza e la sicurezza delle informazioni armonizzato alla norma UNI CEI EN ISO/IEC 27001 e al Framework NIST CSF 2.0. 2025.

5.1 Politica per la sicurezza delle reti e dei sistemi informativi

Tabella 5.1: Confronto tra NIS2, ISO/IEC 27001:2022 e NIST CSF 2.0 – Politica per la sicurezza delle reti e dei sistemi informativi

NIS2	**ISO/IEC 27001:2022**	**NIST CSF 2.0**
21(2)(a): Politica per la sicurezza delle reti e dei sistemi informativi	5.2, A.5.1, A.5.36, A.5.4, 9.3	PR.AT-02, GV.PO-01, GV.PO-02, GV.OC-03, GV.RM-03, GV.OC-02, ID.IM-01, ID.IM-02, ID.IM-03, ID.IM-04
21(2)(a): Ruoli, responsabilità e poteri correlati	5.3, A.5.2, A.5.3, A.5.4	GV.RR-02, GV.SC-02, PR.AT-02, ID.IM-01, ID.IM-02, ID.IM-03, ID.IM-04

5.2 Politica di gestione del rischio

Tabella 5.2: Confronto tra NIS2, ISO/IEC 27001:2022 e NIST CSF 2.0 – Politica di gestione del rischio

NIS2	**ISO/IEC 27001:2022**	**NIST CSF 2.0**
21(2)(a): Quadro per la gestione del rischio	6.1, 6.1.2, 6.1.3, 6.2, 8.2, 8.3, A.5.7, A.5.19, A.5.20, A.5.21	ID.RA-01, ID.RA-02, ID.RA-03, ID.RA-04, ID.RA-05, ID.RA-06, GV.RM-03, ID.RM-01, GV.RM-06, GV.RR-03, ID.IM-01, ID.IM-02, ID.IM-03, ID.IM-04
21(2)(a): Monitoraggio della conformità	9.2, A.5.31, A.5.35, A.5.36	GV.OV-02, ID.IM-01, ID.IM-02, ID.IM-03, ID.IM-04
21(2)(a): Riesame indipendente della sicurezza delle reti e delle informazioni	9.2, 10.1, A.5.35, A.8.34	GV.OV-02, ID.IM-01

5.3 Gestione degli incidenti

Tabella 5.3: Confronto tra NIS2, ISO/IEC 27001:2022 e NIST CSF 2.0 – Gestione degli incidenti

NIS2	**ISO/IEC 27001:2022**	**NIST CSF 2.0**
21(2)(b): Politica per la gestione degli incidenti	A.5.24	GV.SC-08, RS.MA-01, RS.MA-05, RS.MI-01, RS.MI-02, ID.IM-01, ID.IM-04
21(2)(b): Monitoraggio e registrazione (logging)	A.5.28, A.8.15, A.8.16, A.8.17	RS.AN-06, RS.AN-07, ID.IM-01, ID.IM-02, ID.IM-03, ID.IM-04
21(2)(b): Segnalazione degli eventi	A.6.8	RS.MI-01, RS.CO-02
21(2)(b): Valutazione e classificazione degli eventi	A.5.25	DE.AE-04, RS.MA-02, RS.MA-03, RS.MA-04, ID.IM-01, ID.IM-02, ID.IM-03, ID.IM-04

NIS2	ISO/IEC 27001:2022	NIST CSF 2.0
21(2)(b): Risposta agli incidenti	A.5.26	RS.MA-01, RS.MA-02, RS.MA-03, RS.MA-04, ID.IM-02, ID.IM-03, ID.IM-04, RS.CO-02, RS.CO-03, RS.AN-03, RS.MI-01, RS.MI-02, RC.CO-03, RC.CO-04
21(2)(b): Riesami post-incidente	A.5.27	ID.IM-01, ID.IM-04, RS.AN-08

5.4 Continuità operativa e gestione delle crisi

Tabella 5.4: Confronto tra NIS2, ISO/IEC 27001:2022 e NIST CSF 2.0 – Continuità operativa e gestione delle crisi

NIS2	ISO/IEC 27001:2022	NIST CSF 2.0
21(2)(c): Piano di continuità operativa e ripristino in caso di disastro	A.5.29, A.5.30	ID.IM-02, ID.IM-03, ID.IM-04, GV.OC-04, GV.SC-08, RC.RP-01, RC.RP-02
21(2)(c): Gestione dei backup	A.8.13, A.8.14	PR.DS-11, RC.RP-01, RC.RP-02, ID.IM-03
21(2)(c): Gestione delle crisi	A.5.26, A.5.29, A.5.30	RS.CO-02, RS.CO-03, PR.IR-03, DE.CM-01, ID.AM-03, DE.AE-02, DE.AE-03, DE.AE-04, DE.AE-06, DE.AE-07, DE.AE-08

5.5 Sicurezza della catena di fornitura

Tabella 5.5: Confronto tra NIS2, ISO/IEC 27001:2022 e NIST CSF 2.0 – Sicurezza della catena di fornitura

NIS2	**ISO/IEC 27001:2022**	**NIST CSF 2.0**
21(2)(d): Politica per la sicurezza della catena di fornitura	A.5.19, A.5.20, A.5.21, A.8.30	GV.OC-03, GV.OC-05, GV.SC-01, GV.SC-04, GV.SC-06, GV.SC-05, GV.SC-07, GV.SC-09, GV.SC-10, ID.RA-10, ID.IM-01, ID.IM-02, ID.IM-03, ID.IM-04
21(2)(d): Elenco di fornitori e prestatori di servizi	A.5.22	GV.OC-05, GV.SC-04, ID.IM-01, ID.IM-02, ID.IM-03, ID.IM-04

5.6 Sicurezza nell'acquisizione, nello sviluppo e nella manutenzione di sistemi e servizi ICT

Tabella 5.6: Confronto tra NIS2, ISO/IEC 27001:2022 e NIST CSF 2.0 – Sicurezza nell'acquisizione, nello sviluppo e nella manutenzione di sistemi e servizi ICT

NIS2	**ISO/IEC 27001:2022**	**NIST CSF 2.0**
21(2)(e): Sicurezza di servizi, sistemi o prodotti ICT	A.5.21, A.5.23	GV.PO-02, GV.SC-06, ID.RA-09, ID.RA-10, ID.IM-01, ID.IM-02, ID.IM-03, ID.IM-04
21(2)(e): Ciclo di sviluppo sicuro (SDLC)	A.8.25, A.8.31	ID.AM-08, PR.PS-06, ID.IM-01, ID.IM-02, ID.IM-03, ID.IM-04
21(2)(e): Gestione della configurazione	A.8.9	PR.PS-01, ID.IM-01, ID.IM-02, ID.IM-03, ID.IM-04
21(2)(e): Gestione dei cambiamenti, riparazioni e manutenzione	6.3, 8.1, A.7.13, A.8.32	ID.RA-07, ID.IM-01, ID.IM-02, ID.IM-03, ID.IM-04
21(2)(e): Verifiche di sicurezza	A.8.29, A.8.33, A.8.34	ID.RA-01, ID.IM-01, ID.IM-02, ID.IM-03, ID.IM-04

NIS2	ISO/IEC 27001:2022	NIST CSF 2.0
21(2)(e): Gestione delle patch di sicurezza	A.8.31, A.8.32	PR.PS-02, DE.CM-09, ID.IM-01, ID.IM-02, ID.IM-03, ID.IM-04
21(2)(e): Sicurezza di rete	A.8.16, A.8.20	DE.CM-01, PR.IR-01, PR.PS-05, ID.IM-01, ID.IM-02, ID.IM-03, ID.IM-04
21(2)(e): Segmentazione di rete	A.8.22	PR.IR-01, ID.IM-01, ID.IM-02, ID.IM-03, ID.IM-04
21(2)(e): Protezione da software dannoso e non autorizzato	A.5.32, A.8.7	DE.CM-01, DE.CM-09, PR.PS-05, ID.IM-01, ID.IM-02, ID.IM-03, ID.IM-04
21(2)(e): Gestione e divulgazione delle vulnerabilità	A.8.8	ID.RA-01, ID.RA-02, ID.RA-04, ID.RA-05, ID.RA-06, PR.PS-02, PR.PS-03, ID.RA-08, ID.IM-01, ID.IM-02, ID.IM-03, ID.IM-04

5.7 Politiche e procedure per valutare l'efficacia delle misure di gestione del rischio di cybersicurezza

Tabella 5.7: Confronto tra NIS2, ISO/IEC 27001:2022 e NIST CSF 2.0 – Politiche e procedure per valutare l'efficacia delle misure di gestione del rischio di cybersicurezza

NIS2	ISO/IEC 27001:2022	NIST CSF 2.0
21(2)(f): Politiche e procedure di valutazione dell'efficacia	6.2, 9.1, 9.3	ID.IM-03, GV.RM-06, ID.IM-01, ID.IM-02, ID.IM-03, ID.IM-04

5.8 Buone pratiche di igiene informatica e formazione sulla sicurezza

Tabella 5.8: Confronto tra NIS2, ISO/IEC 27001:2022 e NIST CSF 2.0 – Buone pratiche di igiene informatica e formazione sulla sicurezza

NIS2	**ISO/IEC 27001:2022**	**NIST CSF 2.0**
21(2)(g): Sensibilizzazione e buone pratiche di igiene informatica	7.3, A.6.3, A.8.7	PR.AT-01, PR.AT-02, ID.IM-01, ID.IM-02, ID.IM-03, ID.IM-04
21(2)(g): Formazione sulla sicurezza	7.2, A.6.3	PR.AT-01, ID.IM-01, ID.IM-02, ID.IM-03, ID.IM-04

5.9 Crittografia

Tabella 5.9: Confronto tra NIS2, ISO/IEC 27001:2022 e NIST CSF 2.0 – Crittografia

NIS2	**ISO/IEC 27001:2022**	**NIST CSF 2.0**
21(2)(h): Crittografia	A.5.31, A.8.24	PR.DS-01, PR.DS-02, ID.IM-01, ID.IM-02, ID.IM-03, ID.IM-04

5.10 Sicurezza delle risorse umane

Tabella 5.10: Confronto tra NIS2, ISO/IEC 27001:2022 e NIST CSF 2.0 – Sicurezza delle risorse umane

NIS2	**ISO/IEC 27001:2022**	**NIST CSF 2.0**
21(2)(i): Sicurezza delle risorse umane	7.1, 7.2, A.6.2, A.6.3	PR.AT-02, GV.RR-04, ID.IM-01, ID.IM-02, ID.IM-03, ID.IM-04
21(2)(i): Verifica dei precedenti	A.6.1	GV.RR-04, ID.IM-01, ID.IM-02, ID.IM-03, ID.IM-04
21(2)(i): Procedure di cessazione o variazione del rapporto di lavoro	A.6.5	GV.RR-04
21(2)(i): Procedimento disciplinare	A.6.4	ID.IM-01, ID.IM-02, ID.IM-03, ID.IM-04

5.11 Controllo degli accessi

Tabella 5.11: Confronto tra NIS2, ISO/IEC 27001:2022 e NIST CSF 2.0 – Controllo degli accessi

NIS2	**ISO/IEC 27001:2022**	**NIST CSF 2.0**
21(2)(i): Politica di controllo degli accessi	A.5.15, A.7.2, A.8.3, A.8.21, A.9	PR.AA-05, ID.IM-01, ID.IM-02, ID.IM-03, ID.IM-04
21(2)(i): Gestione dei diritti di accesso	A.5.18, A.9	PR.AA-05, ID.IM-01, ID.IM-02, ID.IM-03, ID.IM-04
21(2)(i): Account privilegiati e account di amministrazione dei sistemi	A.8.2, A.8.18, A.9	ID.IM-01, ID.IM-02, ID.IM-03, ID.IM-04
21(2)(i): Sistemi di amministrazione	A.8.2, A.8.18	Nessuna corrispondenza diretta
21(2)(i): Identificazione	A.5.16	PR.AA-01, PR.AA-05, PR.AC-02
21(2)(i): Autenticazione	A.5.17	PR.AA-05, PR.AA-03, ID.IM-01, ID.IM-02, ID.IM-03, ID.IM-04
21(2)(i): Autenticazione a più fattori	A.8.5	PR.AA-03

5.12 Gestione degli asset

Tabella 5.12: Confronto tra NIS2, ISO/IEC 27001:2022 e NIST CSF 2.0 – Gestione degli asset

NIS2	**ISO/IEC 27001:2022**	**NIST CSF 2.0**
21(2)(i): Classificazione degli asset	A.5.9, A.5.12, A.5.13	ID.AM-05
21(2)(i): Trattamento degli asset	A.5.9, A.5.10, A.5.14, A.7.10	ID.IM-01
21(2)(i): Politica sui supporti rimovibili	A.7.7, A.7.10	PR.DS-01, ID.IM-01, ID.IM-02, ID.IM-03, ID.IM-04

NIS2	ISO/IEC 27001:2022	NIST CSF 2.0
21(2)(i): Inventario degli asset	A.5.9	ID.AM-01, ID.AM-02, ID.AM-03, ID.AM-04, ID.AM-07, ID.AM-08, ID.IM-01, ID.IM-02, ID.IM-03, ID.IM-04
21(2)(i): Consegna, restituzione o cancellazione degli asset alla cessazione del rapporto di lavoro	A.5.11, A.5.18, A.8.24	Nessuna corrispondenza diretta

5.13 Sicurezza fisica e ambientale

Tabella 5.13: Confronto tra NIS2, ISO/IEC 27001:2022 e NIST CSF 2.0 – Sicurezza fisica e ambientale

NIS2	ISO/IEC 27001:2022	NIST CSF 2.0
21(2)(c): Servizi di supporto (utilities)	A.7.11	DE.CM-02, DE.CM-06, GV.OC-03, GV.OC-05, GV.OC-07, ID.RA-10, ID.IM-01, ID.IM-02, ID.IM-03, ID.IM-04
21(2)(e): Protezione dalle minacce fisiche e ambientali	A.7.3, A.7.5	PR.IR-02, ID.IM-01, ID.IM-02, ID.IM-03, ID.IM-04
21(2)(i): Perimetro e controllo degli accessi fisici	A.7.1, A.7.2, A.7.4	PR.AA-06, DE.CM-02

Capitolo 6

La figura del CISO nell'adempimento della Direttiva NIS2

6.1 CISO: compiti ed evoluzione della figura

6.1.1 Compiti del CISO

Grazie al contributo di Matteo Herin, CISO & Head of AI Cybersecurity presso Carrefour Italia, e di Michele Rivieri, CISO di Prometeia, è possibile delineare i principali compiti del Chief Information Security Officer in un'organizzazione. A supporto di quanto reperito dalle interviste, le informazioni sono integrate con il testo Barry S. Kouns e Jake Kouns. *The CISO Perspective: Understand the importance of the CISO in the cyber threat landscape.* IT Governance Publishing, 2023.

Come racconta Herin, la funzione cybersecurity nel mondo aziendale ricopre il ruolo di organo di controllo di primo livello: ha un ruolo di mediazione tra gli obiettivi e le scadenze della produzione e la necessità di ottemperare a determinati standard che forniscano sicurezza all'organizzazione e a tutti i suoi asset, tra cui anche a tutte le persone da cui è formata.

In quest'ottica, i compiti del CISO si articolano su cinque macrocategorie:

1. **Governance e gestione del rischio**
2. **Gestione della *security by design***
3. **Gestione delle operations**

4. **Gestione dell'innovazione**

5. **Training e *awareness***

Tale suddivisione dei compiti è coerente con le task del CISO individuate da ENISA in relazione agli obblighi stabiliti da NIS2[1].

Governance e gestione del rischio Tra le attività di governance e gestione del rischio rientrano la definizione di policy di sicurezza e procedure da seguire, l'interazione con gli altri organi aziendali, le attività di risk assessment, la compliance normativa e la gestione degli audit nell'ambito della sicurezza informatica.

Il ciclo di risk management richiede infatti un insieme di policy coerente (una principale a livello di business corredata da altre specifiche per ogni area di rischio identificata), indicatori/KPI per monitorare efficacia e maturità delle misure, e riesami pianificati o basati su incidenti significativi, cambiamenti organizzativi o di minaccia, con decisioni di accettazione del rischio e piani correttivi approvati dal management[2].

Security by design Nella sfera della *security by design* si trovano tutte le azioni volte alla messa in sicurezza e al mantenimento della sicurezza degli asset digitali dell'impresa. L'analisi statica (SAST) e dinamica (DAST) del codice degli applicativi, le attività di *vulnerability assessment* e *penetration testing* antecedenti al rilascio dei servizi digitali, le pratiche di *patching* e aggiornamento periodico sono tutte attività necessarie per prevenire eventuali incidenti e ridurre così in maniera significativa il rischio residuo.

Operations Nell'ambito di *cybersecurity operations* si collocano tutte le procedure di gestione degli eventi di sicurezza, ossia l'analisi e il monitoraggio degli eventi di minaccia, le modalità di risposta, la gestione delle crisi che possono verificarsi in seguito a un incidente. Tutto ciò che fa parte della difesa attiva e passiva dell'organizzazione è dunque oggetto di interesse primario per il CISO.

[1] Adamos, Franco, Leventopoulos e ENISA. *Cybersecurity Roles and Skills for NIS2 Essential and Important Entities: Mapping NIS2 obligations to ECSF*. 2025, p. 23.

[2] Moulinos, Theocharidou e ENISA. *Implementing Guidance on Commission Implementing Regulation (EU) 2024/2690 of 17.10.2024 laying down rules for the application of Directive (EU) 2022/2555 as regards technical and methodological requirements of cybersecurity risk-management measures*. 2024, pp. 9–15, pp. 21–25.

Innovazione Come sottolineato da Herin e Rivieri, l'innovazione non è una tematica confinata alle attività di ricerca e sviluppo dei prodotti e dei processi, ma rappresenta un elemento di interesse trasversale in tutte le aree aziendali, specialmente per la sicurezza informatica. L'evoluzione degli strumenti e dei prodotti digitali porta infatti innumerevoli nuove minacce e potenzialità di attacco che ogni azienda deve prontamente identificare e arginare quanto prima. Le attività di *cyber threat intelligence*, ricerca e conoscenza delle moderne tecniche a disposizione dei cybercriminali, identificazione di nuove vulnerabilità ed exploit, rappresentano la prima attività a difesa dell'organizzazione contro i fattori esterni.

In quest'ottica, il continuo dialogo con la community rappresenta uno strumento efficace attraverso cui gestire l'innovazione. Herin e Rivieri partecipano alla community CISO italiana, una tra le più sviluppate e proattive in questo ambito, la quale rappresenta una rete di esperti della sicurezza informatica che documentano le nuove scoperte e le condividono al fine di diffondere la conoscenza e aiutare la protezione delle aziende.

Formazione

> *"Il fattore umano è l'anello più debole della sicurezza.*[3] *"*

La citazione di Kevin Mitnick, hacker tra i più noti della storia, individua la principale problematica delle aziende quando si parla di sicurezza, in ambito informatico e non: il fattore umano. Come riportato nell'introduzione all'elaborato, il social engineering è tra le pratiche più usate per penetrare le organizzazioni e le stesse devono quindi investire nella formazione dei propri dipendenti, oltre a rinforzare i propri sistemi, per evitare accessi non autorizzati, furti di dati e altri cybercrimini. Qui entra in gioco nuovamente il CISO, che ha il compito di coordinare la formazione non solo dei dipendenti, ma anche della direzione aziendale responsabile anche delle decisioni in questo ambito. Herin sottolinea come la comunicazione in questo processo svolga un ruolo centrale: è fondamentale adottare una comunicazione adeguata al target a cui si rivolgono le informazioni per fare in modo che il messaggio sia recepito in maniera chiara e che l'interlocutore si senta responsabile delle proprie azioni nel quadro della sicurezza aziendale. Parte del processo di educazione alla sicurezza informatica di competenza del CISO riguarda quindi l'individuazione delle aree

[3]Mitnick e Simon. *L'arte dell'inganno. I consigli del più famoso hacker del mondo per ingannare chiunque e proteggersi da chiunque*. Feltrinelli. 2003.

e dei soggetti più a rischio per allocare le risorse formative nel modo più efficace possibile per l'organizzazione.

6.1.2 Evoluzione del ruolo del CISO

La definizione dei compiti del CISO sopra riportata consente di riflettere attentamente su come è cambiato questa funzione aziendale con la forte evoluzione delle minacce informatiche e i nuovi approcci delle organizzazioni e delle autorità per gestirle.

Come emergerà anche dalle sezioni successive, il CISO concentra le proprie attività non più esclusivamente sugli aspetti tecnici e sull'expertise individuale, ma sulla leadership, sulla gestione del rischio e sull'allineamento con gli obiettivi di business. La sua funzione evolve da quella di mero specialista operativo a quella di facilitatore di business, capace di integrare la sicurezza informatica nei processi decisionali e strategici dell'organizzazione, traducendo il linguaggio tecnico in termini di rischio, valore e priorità per l'impresa[4].

Per riassumere visivamente la recente evoluzione di questo ruolo e dei compiti che è chiamato a svolgere, si riporta di seguito una tabella tratta da Kouns e Kouns, *The CISO Perspective: Understand the importance of the CISO in the cyber threat landscape* che racchiude le principali differenze tra il CISO di ieri e quello di oggi.

Tabella 6.1: Evoluzione della descrizione del ruolo del CISO[5]

CISO di ieri	**CISO di oggi**
Esperto tecnico	Consulente di fiducia (*Trusted adviser*)
Analista	Facilitatore e leader (*Facilitator and leader*)
Esperto di rischio tecnico	Responsabile della gestione del rischio (*Risk manager*)
Contributore individuale	Pensatore strategico integrato nel business (*Integrative business thinker*)
Chief Security Officer	Chief Risk Officer
Amministratore	Stratega (*Strategist*)
Manager	Visionario (*Visionary*)

[4]Kouns e Kouns. *The CISO Perspective: Understand the importance of the CISO in the cyber threat landscape*. IT Governance Publishing. 2023, pp. 32–34.

6.2 Con chi interagisce il CISO

Come visto, il CISO svolge funzioni di carattere trasversale, interessando molteplici aree aziendali e interagendo con livelli profondamente differenti tra loro per competenze, compiti e ruolo gerarchico. È naturale dunque che il CISO sia quotidianamente a contatto con diversi interlocutori, i cui principali, secondo Herin, sono:

- il dipartimento IT, per l'implementazione delle misure di sicurezza informatica e le attività di monitoraggio dei sistemi;
- i dipartimenti digital e marketing, che gestiscono ad esempio il sito web e l'applicazione mobile dell'azienda, ove presenti;
- l'area di produzione, per quanto riguarda la gestione delle componenti di *industrial technology*;
- il dipartimento HR, per le attività di formazione;
- l'area legale, per la compliance normativa nell'area della cybersicurezza;
- l'area di internal audit, al fine di comprendere la struttura e gli asset aziendali e l'implementazione di un framework di controllo periodico;
- il dipartimento per le pubbliche relazioni, utile nel caso in cui sia necessario comunicare con gli stakeholder esterni all'azienda, ad esempio per la comunicazione di incidenti di sicurezza che potrebbero provocare loro danni;
- la sicurezza fisica, fondamentale per il controllo dell'accesso fisico alle macchine, prima porta di ingresso ai sistemi e ai dati aziendali da proteggere;

In questo complesso contesto di interazioni, la guida ENISA sui ruoli per la gestione della cybersicurezza individua un ulteriore partner naturale del CISO nella figura del *Cyber Legal, Policy and Compliance Officer*, appartenente all'area legale[6] Tale funzione può coadiuvare il CISO nello svolgimento dei propri compiti, soprattutto nel caso di aziende di grandi dimensioni operanti su industrie molto differenziate tra loro e conseguentemente soggette a numerosi requisiti di carattere normativo.

[6]Adamos, Franco, Leventopoulos e ENISA. *Cybersecurity Roles and Skills for NIS2 Essential and Important Entities: Mapping NIS2 obligations to ECSF*. 2025, pp. 24–25.

6.2.1 Dialogo con gli organi di gestione

Gli obblighi introdotti dalla nuova Direttiva NIS2 hanno rafforzato la necessità del CISO di dialogare con le figure dell'area dirigenziale e del top management per comunicare le strategie, i risultati, i dati e le analisi periodiche sullo stato di salute cibernetica dell'azienda. Pur essendo le strutture aziendali molto diverse tra loro, è possibile delineare una metodologia di base comune per il dialogo in materia di sicurezza informatica, in cui il CISO ricopre il ruolo di interlocutore strategico del CdA[7].

Solitamente, spiega Herin, si tiene un comitato di sicurezza periodico ogni mese o ogni due mesi, in cui il team di cybersecurity espone lo stato dell'arte e sottomette al comitato stesso le decisioni da prendere. A questo tavolo partecipano i direttori delle aree IT, sicurezza fisica, audit, privacy ed eventualmente referenti per la funzione HR o altre funzioni interessate dalle tematiche trattate. Si tratta quindi di un comitato tecnico, con l'obiettivo di condividere le analisi sulla situazione corrente, confrontarsi sul raggiungimento degli obiettivi e definire le priorità strategiche per la sicurezza.

Più di rado, circa una o due volte all'anno, si svolge invece il comitato di direzione per la sicurezza informatica, cui partecipa una delegazione del team di cybersecurity e il comitato di direzione aziendale. Si tratta in questo caso di una discussione ad alto livello, con l'obiettivo di definire il budget, il profilo di rischio aziendale e i cambiamenti in atto. In questa fase si sottopongono le questioni critiche al management, che ha il compito di assumere le adeguate decisioni.

Dalla discussione con Herin emerge anche una metodologia precisa per la costruzione della strategia e del budgeting: cybersecurity non ha obiettivi stabiliti a priori, bensì deve fronteggiare la sfida di adattarsi ai cambiamenti introdotti dalle decisioni strategiche nelle aree *core business*, definendo le proprie in relazione alle criticità introdotte. Si tratta quindi di un approccio adattivo. Herin osserva infatti che l'obiettivo della cybersicurezza sia quello di assistere le funzioni principali, permettendo loro di operare efficacemente ed efficientemente, ma rispettando determinati standard di sicurezza.

[7]Kouns e Kouns. *The CISO Perspective: Understand the importance of the CISO in the cyber threat landscape*. IT Governance Publishing. 2023, pp. 25–38.

6.3 Gestione del rischio

Herin evidenzia come, ad oggi, le attività di cybersecurity aziendale siano fortemente legate all'analisi, al trattamento e alle strategie di gestione del rischio e non più alla mera supervisione dell'implementazione di meccanismi di difesa informatici. Il profilo di rischio desiderato dall'azienda guida infatti le decisioni strategiche e di investimento, con l'obiettivo di allocare le risorse nel modo più efficiente possibile, minimizzando il rischio residuo.

Per il raggiungimento di tale obiettivo le aziende, in particolar modo quelle più strutturate, dispongono di un *risk office* che si occupa di:

- effettuare periodicamente attività di *risk assessment* per analizzare il profilo di rischio corrente dell'azienda;
- elaborare un *risk framework* sulla base delle rilevazioni svolte e delle necessità individuate, con l'obiettivo di fornire uno strumento per uniformare le decisioni per la gestione del rischio a livello aziendale.

Il risk framework aiuta quindi il CISO a valutare il livello di rischio di ogni servizio digitale[8], attraverso la stima di tre fattori:

1. minaccia, ovvero una valutazione della fonte di rischio;
2. probabilità, cioè la facilità con cui una minaccia può concretizzarsi per l'azienda nello specifico;
3. impatto, ossia le conseguenze che la minaccia può avere sull'organizzazione.

Il framework permette di calcolare un valore (secondo il *Common vulnerability Scoring System*) a partire da questi tre fattori e stabilisce le soglie di accettabilità del rischio. Seguendo questa indicazione, il CISO decide se:

- cessare il rischio;
- trattare il rischio;
- trasferire il rischio;

[8]Kouns e Kouns. *The CISO Perspective: Understand the importance of the CISO in the cyber threat landscape*. IT Governance Publishing. 2023, pp. 40–42.

- accettare il rischio.

In particolare, Herin sottolinea come il CISO sia responsabile per le decisioni in merito ai rischi che riguardano strettamente la cybersicurezza. In linea generale, chi è responsabile dei rischi di un asset digitale è l'*application owner* di tale asset, definendo un preciso framework di *ownership* e responsabilità. Così, ad esempio, il CISO è responsabile degli applicativi *cyber for cyber* dell'azienda, ma non per i rischi connessi ad applicativi esterni, i quali avranno un proprio responsabile definito.

6.4 Adempimento della Direttiva NIS2 nelle organizzazioni

6.4.1 Ruolo e responsabilità del CISO

In materia di NIS2, il CISO svolge la funzione di punto di contatto richiesta dal legislatore. La compliance normativa in ambito cyber è infatti uno dei compiti a carico del CISO, che si occupa di definire le politiche, le procedure e i comportamenti da adottare nell'organizzazione per conformarsi, in questo caso, alla Direttiva NIS2.

Un primo elemento di novità introdotto da NIS2 nei compiti del CISO, osservano Herin e Rivieri, è il fatto che la direttiva non fornisca semplicemente controlli da implementare e adempimenti da dimostrare, ma introduca anche la valutazione del rischio in questo processo. Infatti, le misure stabilite nella norma, oltre ad applicarsi differentemente a seconda della classificazione del soggetto in *essenziale* e *importante*, si attuano anche in funzione del rischio. Può accadere quindi che, per due soggetti classificati ugualmente e operanti in business differenti, alcuni controlli si ritengano necessari nell'uno e non nell'altro caso. Spetta dunque al CISO, sulla base di un'analisi di rischio rispetto al profilo richiesto dalla normativa all'azienda, individuare le vulnerabilità critiche da sanare e presentarle al rispettivo *risk owner* per decidere come gestire tale fattore di rischio.

Inoltre, in entrambe le interviste con i CISO emerge una questione importante riguardo alle responsabilità in ambito NIS2. La normativa infatti specifica esplicitamente che i responsabili dell'implementazione delle misure stabilite siano gli organi dirigenziali dell'azienda, mentre il CISO non è imputabile direttamente come responsabile dalle autorità in caso di mancato adempimento. Il suo ruolo è infatti a livello più tecnico e operativo:

ciò che rientra nelle sue competenze è l'attuazione concreta dei controlli stabiliti dal framework e l'individuazione delle vulnerabilità, ponendo quindi tra le sue responsabilità la corretta realizzazione dei meccanismi di cybersicurezza, ma non l'adempimento normativo in senso stretto. In altri termini, il CISO è la figura deputata a *far funzionare correttamente la macchina* che implementa il framework NIS2, sovrintendendone l'adozione delle misure.

Appreso dunque che NIS2 non introduce nessuna nuova responsabilità operativa per la figura del CISO, Michele Rivieri sottolinea come, invece, abbia introdotto obblighi sul piano informativo e relazionale: dal momento che il CdA è responsabile della sicurezza, il compito del CISO è quello di informare periodicamente il top management riguardo i rischi informatici cui l'azienda è esposta, il profilo attuale, quello desiderato e le aree di investimento in cui operare a livello strategico. Tale interazione era presente anche in precedenza, ma Rivieri precisa che NIS2 ne ha modificato la natura da due punti di vista:

- l'attribuzione formale di responsabilità al management implica una maggiore frequenza di interazione con gli organi deputati a decidere in merito ai rischi informatici, che devono essere informati periodicamente, come descritto nelle sezioni precedenti;

- i *risk owner* veri e propri, ovvero coloro che devono decidere in merito alla gestione dei rischi dei propri applicativi, fanno capo al CdA in quanto organo che ha capacità di spesa in caso di non accettazione del rischio.

In questo contesto, la Direttiva NIS2 introduce un significativo cambiamento nei rapporti di forza interni alle organizzazioni: l'attribuzione di responsabilità dirette al top management per la conformità alle misure di sicurezza — e per gli eventuali inadempimenti — trasforma la cybersicurezza da questione meramente tecnica a tema strategico e di governance. La prospettiva di sanzioni economiche e reputazionali, unite alla possibilità di responsabilità personali degli amministratori, induce il management a una nuova consapevolezza del rischio informatico e ad attribuire maggiore attenzione alle raccomandazioni provenienti dall'area di sicurezza. Ne deriva che il CISO, da figura spesso confinata in un ruolo consulenziale e tecnico, assume una posizione di effettiva influenza sulle decisioni aziendali, potendo incidere in modo sostanziale sulla definizione delle priorità di investimento, sulle strategie di gestione del rischio e sull'integrazione della sicurezza nei processi

di business. Dal dialogo con i CISO emerge quindi la necessità di formare le figure addette alla cybersicurezza non solo dal punto di vista tecnico e operativo, ma anche sotto gli aspetti economici, strategici e organizzativi, parte integrante della gestione della sicurezza in ambito aziendale.

6.4.2 Delega di responsabilità

La gestione della responsabilità secondo NIS2 avviene in maniera rigida e inderogabile: la normativa assegna la responsabilità della sicurezza informatica agli organi di gestione e per adempiere a tale obbligo non è dunque possibile adottare meccanismi di delega.

Il CISO di Prometeia sottolinea come questo obbligo normativo costituisca un problema rilevante a livello organizzativo, su cui ogni azienda deve interrogarsi e sviluppare un processo ben definito: se è vero che non è possibile delegare la sicurezza al CISO è allora necessario sottomettere ogni decisione in ambito di sicurezza al CdA. Tuttavia, come osserva Rivieri, questo assetto comporta un notevole rallentamento dei processi decisionali e la mancanza di competenze specifiche di sicurezza informatica determina un'ulteriore inibizione della capacità decisionale in materia.

Non essendo dunque possibile richiedere agli organi di gestione di farsi carico di tutte le scelte strategiche sulla cybersicurezza, come invece un'applicazione ligia di NIS2 richiederebbe, le aziende devono implementare una qualche forma di delega implicita. La soluzione migliore secondo Rivieri rimane il confronto periodico con il CdA, rimandando a tale circostanza le decisioni più impattanti a livello di business, mentre quelle di rilevanza minore possono essere gestite direttamente dal CISO e dal team cybersecurity. La sicurezza informatica è infatti un processo giornaliero, data la grande velocità con cui evolvono gli scenari, e rinunciare al meccanismo della delega implicherebbe uno svantaggio notevole nella gestione delle minacce cyber.

Tuttavia, Herin e Rivieri concordano nel riconoscere un ruolo centrale alla formazione del top management: senza la possibilità di comprendere i rischi che l'azienda affronta gli organi di gestione non hanno capacità decisionale e la definizione di una strategia di cybersicurezza diventerebbe la mera accettazione di quanto presentato dal CISO. Ciò andrebbe contro la normativa NIS2, che riconosce nel CdA un ulteriore organo di controllo all'interno della catena della sicurezza aziendale, con un ruolo attivo nella gestione dei rischi che l'impresa affronta.

6.5 Ruolo degli standard secondo i CISO

La struttura di NIS2, dettagliata nella descrizione dei controlli e delle responsabilità, ne permette un utilizzo diretto proprio come un framework di cybersecurity. Herin sostiene infatti che, laddove l'azienda non abbia già implementato standard per la cybersicurezza, l'approccio migliore sia quello di progettare la strategia di sicurezza informatica direttamente sulla normativa. In questo modo, le aziende possono soddisfare gli obblighi imposti dal regolatore in maniera mirata, strutturando la governance e le policy in modo da essere conformi a quanto richiesto.

Piuttosto che adottare uno standard per favorire l'applicazione di NIS2, Herin suggerisce il processo contrario: visti i numerosi punti in comune, una volta fissate le misure per NIS2 è possibile anche adattare le scelte in funzione dell'adozione di ISO 27001 o del NIST CSF 2.0, piuttosto che di altri standard che l'azienda individua come strategicamente rilevanti. Infatti, se passare da uno standard per arrivare alla normativa può apparire controintuitivo, data l'obbligatorietà della seconda e la natura volontaria del primo, il processo contrario può portare diversi vantaggi: da un lato, consente di concentrare le risorse sulla realizzazione dei requisiti obbligatori, garantendo la compliance, e dall'altro struttura tale base per la futura adozione di framework, i quali ricicleranno i controlli compatibili già implementati, aggiungendone di nuovi o adattando quelli esistenti ove necessario.

Tuttavia, è importante notare che, trattandosi di una normativa e non un testo tecnico, il linguaggio adottato e le modalità di presentazione dei controlli lasciano un certo spazio all'interpretazione[9]. Ciò dipende in larga misura anche dalla maturità delle procedure di sicurezza informatica già adottate dall'azienda: i soggetti con un livello di maturità della sicurezza superiore avranno la necessità di individuare solamente le aree in cui risultano carenti rispetto a NIS2, mentre le entità che per la prima volta rientrano in un regime di regolamentazione delle misure di cybersicurezza dovranno implementare una strategia efficace da zero. In quest'ultima casistica, che può presentare notevoli sfide per le aziende, come visto nel Capitolo 2, gli standard di cybersicurezza rappresentano un valido strumento a supporto dell'organizzazione e del CISO. Per arrivare al piano d'azione concreto a partire dalla normativa, la letteratura suggerisce infatti di elaborare una strategia in-

[9]Parmar e Miles. *Cyber Security Frameworks (CSFs): An Assessment Between the NIST CSF v2.0 and EU Standards.* IEEE. 2024, p. 3.

tegrando le misure NIS2 nel contesto di uno (o più) framework di sicurezza informatica, secondo lo schema presentato in figura (Fig. 6.1)[10].

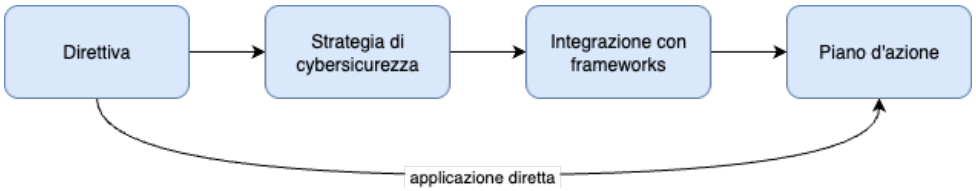


Figura 6.1: Flusso di implementazione della direttiva NIS2[11]

I framework, dunque, si inseriscono nel contesto organizzativo come facilitatori per l'adozione di NIS2, creando una solida base di controlli, procedure e governance da integrare secondo gli obblighi specifici previsti dalle normative, ma non essenziali per l'adempimento di NIS2, come evidenziato dall'analisi condotta nel Capitolo 4.

[10]Parmar e Miles. *Cyber Security Frameworks (CSFs): An Assessment Between the NIST CSF v2.0 and EU Standards.* IEEE. 2024, p. 5.

Capitolo 7

Conclusioni

In questo capitolo si riportano le conclusioni tratte da quanto discusso nei capitoli precedenti di questo elaborato sui temi principali affrontati, ovvero:

- le implicazioni organizzative della Direttiva NIS2;
- il ruolo dei principali framework e standard internazionali nell'adozione di tale direttiva;
- il ruolo della figura del CISO all'interno dell'azienda, le sue responsabilità e i suoi compiti in relazione all'adozione di NIS2.

Inoltre, essendo la Direttiva NIS2 di recente creazione, si aggiunge una breve riflessione sul futuro impatto di tale normativa sullo scenario europeo e sul ruolo delle nuove evoluzioni tecnologiche, come l'intelligenza artificiale, nel contesto della cybersicurezza.

7.1 Implicazioni organizzative della Direttiva NIS2

7.1.1 Responsabilità nella gestione del rischio

La principale novità introdotta da NIS2 è certamente l'attribuzione della responsabilità della sicurezza informatica agli organi di gestione dell'azienda. Infatti, pur essendo già responsabile di tutto ciò che avviene all'interno dell'organizzazione, con questa misura si formalizza il ruolo del CdA come supervisore delle misure di cybersicurezza e la non delegabilità di tale funzione a organi aziendali sottoposti. Inoltre, i componenti dell'amministrazione sono anche direttamente sanzionabili in caso di inadempimenti normativi

in materia di NIS2, con cospicue ammende economiche e sospensioni dal proprio incarico nelle casistiche di maggiore gravità.

Le implicazioni di questo provvedimento sono molteplici e si riflettono direttamente sulla funzione di cybersicurezza aziendale e, di conseguenza, sul CISO. Tale figura si trova dunque formalmente sollevata da responsabilità dirette riguardanti l'inadempimento normativo, ma d'altro canto deve assicurare la corretta implementazione delle misure richieste, individuare eventuali lacune e coadiuvare il CdA nella conformità normativa. La gestione della cybersecurity da parte dell'amministrazione richiede infatti una costante informazione di tali organi, implicando la necessità del CISO di interagire trasversalmente con le altre funzioni aziendali per individuare e valutare le vulnerabilità informatiche. A tal fine, le aziende devono implementare nuovi framework di gestione del rischio che contemplino la sicurezza informatica come componente centrale, nonché specifici meccanismi di periodico dialogo e formazione in materia.

7.1.2 Misure di sicurezza e sicurezza della supply chain

Un ulteriore punto cardine della Direttiva NIS2 è rappresentato dalla gestione della sicurezza in maniera integrata lungo tutta la filiera produttiva di ogni azienda. Tale disposizione mira a garantire un livello uniforme di sicurezza tra tutte le aziende, assicurando in particolare maggiori livelli di protezione e resilienza verso minacce legate alle interazioni con l'esterno.

NIS2 richiede ai fornitori dei soggetti che rientrano nel campo di applicazione della normativa di implementare meccanismi analoghi a quelli dei clienti per garantire sicurezza lungo tutta la filiera. Ciò si applica, secondo il legislatore, non solo ai fornitori diretti ma anche a tutte le entità identificate come critiche all'interno della catena.

Concretamente, la misura è implementata dalle organizzazioni mediante clausole apposite inserite nel contratto, che assicurino il *commitment* del fornitore per garantire un livello di cybersicurezza conforme. Inoltre, i vincoli contrattuali devono essere affiancati da meccanismi di controllo applicati direttamente dai clienti ai propri partner critici, quali richieste di certificazioni e auditing, valutando periodicamente il profilo di rischio del soggetto.

Il coinvolgimento attivo dei fornitori nel controllo della cybersicurezza estende notevolmente il raggio d'azione della normativa, già superiore rispetto alla precedente NIS. Se

da un lato questo è desiderabile per il legislatore, che mira alla massima diffusione di un livello di sicurezza uniforme, dall'altro rappresenta un ingente aumento di costi per imprese che in precedenza non disponevano di meccanismi di cybersecurity adeguati, mentre ora necessitano di sviluppare metodologie e framework appositi coerentemente con quanto richiesto da NIS2.

7.1.3 Notifica degli incidenti

NIS2 introduce anche meccanismi dettagliati per la notifica di eventi di sicurezza informatica alle autorità. In questo modo il legislatore vuole favorire il monitoraggio della sicurezza da parte degli organi nazionali preposti a tale funzione e, al tempo stesso, fornire alle aziende una metodologia strutturata per la gestione degli incidenti. Le agenzie governative svolgono quindi un ruolo fondamentale per la raccolta delle informazioni su minacce e attacchi informatici e per l'assistenza e il coordinamento dei soggetti durante le crisi.

La normativa fissa precisi indicatori chiave di prestazione (KPI) per la segnalazione di incidenti significativi, stabilendo periodici aggiornamenti dopo ventiquattro e settantadue ore dal verificarsi dell'evento. Trascorso un mese, è richiesto alle imprese un rapporto finale sugli avvenimenti, promuovendo così l'apprendimento e la collaborazione tra le varie aziende, individuando e catalogando le minacce e i relativi piani di risposta.

Per implementare queste disposizioni le imprese devono includere nei propri piani di gestione delle crisi il costante dialogo con le autorità. A tale scopo, la normativa richiede di definire un punto di contatto interno alle organizzazioni che si occupi di dialogare con gli organi governativi e le entità esterne in caso di incidenti, funzione in capo al CISO.

7.1.4 Sfide per le organizzazioni

Le aree su cui le organizzazioni devono agire per adempiere completamente a NIS2 sono molteplici e trasversali rispetto ai differenti core business esistenti e richiedono quindi investimenti nella gestione della cybersicurezza in modo integrato a livello aziendale.

Appare chiaro come, in questo contesto, le entità di dimensioni maggiori o già oggetto di precedenti normative di sicurezza (quali NIS e DORA) siano avvantaggiate in questo processo: esse dispongono di risorse maggiori e spesso sono già dotate di framework di cybersecurity interni. Questi soggetti devono dunque limitarsi a condurre una *gap analysis*

tra le misure implementate e quelle richieste dal legislatore europeo, verificando il proprio profilo e predisponendo investimenti mirati per consolidarlo.

I soggetti più colpiti dal punto di vista delle risorse sono quindi le entità non oggetto di precedenti normative o di dimensioni inferiori, con capacità finanziarie inferiori e minore *know-how* in materia. Esse devono infatti costruire il proprio framework *ex novo*, assumendo figure esperte e modificando i propri processi in modo da soddisfare gli obblighi di NIS2. Ciò comporta ingenti investimenti che, tuttavia, non sempre sono agevoli per aziende in questa situazione. Standard come ISO 27001 e NIST CSF possono rappresentare validi strumenti su cui sviluppare i propri meccanismi di gestione della cybersicurezza, da integrare adeguatamente rispetto a NIS2, rendendo il processo più veloce e contenendo i costi.

Dimensione aziendale	**Disponibilità di risorse**	**Maturità dei sistemi**	**Impatto NIS2**	**Note**
Piccola	Bassa	Assente o minima	Molto elevato	Assenza di funzioni dedicate, carenza di policy e controlli, mancanza di personale qualificato.
Piccola-media	Media	Iniziale	Elevato	Alcune misure implementate, ma governance e risk management deboli.
Media	Media	Intermedia	Medio	Cybersicurezza strutturata, ma approccio parziale e frammentato.
Medio-grande	Elevata	Elevata	Basso	Gestione del rischio formalizzata, framework interni implementati, necessità di adeguamento agli obblighi di notifica.
Grande	Elevata	Completa	Molto basso	Già oggetto di regolamentazione, compliance e interazioni con le autorità integrati nei processi, gap analysis per eventuali carenze.

Tabella 7.2: Impatto atteso della Direttiva NIS2 per classi dimensionali e maturità organizzativa

La tabella 7.2 espone le considerazioni precedenti in una visione sintetica, delineando

l'impatto della Direttiva NIS2 sulle aziende in base alla loro dimensione, alle risorse di cui dispongono e alla maturità dei sistemi di sicurezza informatica precedentemente adottati.

7.2 Ruolo degli standard internazionali nell'adempimento della Direttiva NIS2

7.2.1 ISO/IEC 27001:2022 a confronto con NIS2

La certificazione ISO 27001 rappresenta una delle più adottate a livello mondiale nell'ambito della cybersicurezza. Lo standard fornisce alle aziende una struttura di governance solida e un insieme di controlli di sicurezza da adottare per gestire e mitigare il rischio informatico.

Il principale vantaggio che deriva dall'utilizzo di ISO 27001 relativamente all'adempimento di NIS2 è la governance. ISO fornisce infatti una governance profondamente strutturata e una documentazione approfondita dei processi e delle misure attuate per contrastare le minacce informatiche, imponendo anche una struttura per la definizione delle responsabilità. La certificazione ISO rappresenta quindi per le organizzazioni uno strumento cruciale di accountability che, con un costo relativamente contenuto, permette di dimostrare l'impegno nella cybersicurezza a fronte di audit da parte di autorità esterne.

Anche i controlli dell'*Annex A* coprono le aree individuate come critiche da NIS2, costituendo quindi una solida base per soddisfare gli obblighi normativi: tra essi si ritrovano misure in materia di formazione del personale, *threat intelligence*, continuità operativa e ripristino in caso di incidenti.

ISO è dunque coerente con buona parte della normativa europea, ma non ne soddisfa completamente i requisiti richiesti. Infatti, sebbene alcuni framework di cybersicurezza nazionali equiparino l'adempimento ISO a quello NIS2, i due strumenti differiscono sotto più punti di vista. Si ricorda, inolre, la possibilità di colmare alcune lacune dello standard 27001 rispetto a NIS2 integrando altri standard ISO.

In primo luogo, la certificazione ISO 27001 attesta solamente la presenza di adeguati accorgimenti di sicurezza informatica, ma non ne garantisce l'effettiva efficacia: la modalità implementativa del controllo è lasciata alla singola azienda, la quale deve definirla sulla base del profilo di rischio da essa desiderato. NIS2, al contrario, richiede un'im-

plementazione delle misure effettiva e basata sul livello di rischio ricoperto dall'impresa all'interno del sistema Paese e della propria catena produttiva. Dunque, la certificazione ISO permette alle aziende di dimostrare l'adozione di determinati mezzi di contrasto alle minacce informatiche, ma l'effettiva riduzione del rischio apportata da essi deve essere verificata in relazione al profilo individuato da NIS2 per l'azienda.

Inoltre, data la natura non regolatoria dello standard, ISO non prevede gli obblighi di notifica presenti invece nella direttiva, così come l'attribuzione delle responsabilità e le relative sanzioni verso gli organi di gestione non trovano diretta corrispondenza.

Infine, sebbene ISO presenti controlli dedicati a quest'area di rischio, le misure di sicurezza della catena del valore previste da NIS2 risultano più ampie e pervasive, riguardando anche la necessità di controllo diretto da parte del soggetto sui propri fornitori.

7.2.2 NIST CSF 2.0 a confronto con NIS2

Il framework NIST e la Direttiva NIS2 condividono una struttura simile. Il NIST CSF 2.0 ha infatti una vocazione più operativa rispetto a ISO 27001, rendendolo più aderente alle richieste del legislatore europeo.

Il NIST CSF si presenta come un framework ciclico, ma in esso si delineano due parti ben definite:

- le funzioni *Identify* e *Protect* delineano la normale condizione di operatività dell'impresa e le misure di base per la sicurezza informatica;

- le funzioni *Detect*, *Respond* e *Recover* trattano invece il modo in cui l'organizzazione identifica e reagisce agli attacchi cui è soggetta.

Tutte le funzioni si ergono sulla funzione *Govern*, ponendo la governance al centro della gestione della cybersicurezza aziendale.

L'assetto del framework NIST si riflette nelle misure richieste da NIS2 che, a loro volta, mirano ad abbracciare completamente tutti gli aspetti di cybersicurezza che interessano l'organizzazione, in ogni fase della sua operatività. Inoltre, gli obiettivi stabiliti dal NIST all'interno delle singole funzioni trovano piena corrispondenza tra le misure richieste dal legislatore europeo, così come la gestione dei rischi informatici lungo la filiera produttiva, seppur senza obblighi di controllo espliciti sui fornitori.

Nonostante i numerosi punti di contatto, NIS2 e NIST CSF presentano anche alcune divergenze significative.

Nuovamente, trattandosi di un framework volontario e non di uno strumento di natura regolatoria, gli obblighi di notifica alle autorità e la comunicazione con entità esterne per la gestione degli eventi di cybersicurezza non sono pienamente contemplati nel framework NIST. Esso, infatti, si limita a segnalare la necessità di adottare meccanismi di avviso ai soggetti interessati da eventuali incidenti, mentre NIS2 specifica indicatori espliciti (KPI) e richiede l'implementazione di un piano di gestione delle emergenze che coinvolga le autorità ed eventuali terzi danneggiati dagli eventi.

Tuttavia, il limite più grande del NIST CSF è rappresentato dalla mancanza di una certificazione riconosciuta delle misure adottate conformemente al framework: ciò implica la perdita della possibilità di dimostrare accountability per l'organizzazione, costituendo quindi un punto di profonda distanza rispetto agli obblighi NIS2 per la rendicontazione dei controlli implementati in caso di audit da parte delle agenzie governative di controllo.

7.2.3 Ruolo degli standard internazionali nell'adempimento di NIS2

La Direttiva NIS2 rappresenta un primo passo del legislatore nella direzione di un framework europeo unico per la cybersicurezza. Infatti, seppur mantenga un carattere normativo, delinea le aree in cui agire per assicurare la sicurezza informatica dell'organizzazione, sia per quanto riguarda i controlli sia per l'assegnazione delle responsabilità.

Da questo punto di vista, dunque, un'azienda che si trova per la prima volta a dover implementare misure di sicurezza per adempiere agli obblighi NIS2 può decidere di basarsi direttamente sulla direttiva, sul relativo regolamento operativo e sulle norme di recepimento nazionale – che descrivono i controlli nel dettaglio – per realizzare il proprio framework di cybersicurezza, senza la necessità di adottare standard intermedi. Se realizzato correttamente, ciò favorisce il pieno adempimento normativo sin da subito, senza il bisogno di condurre analisi per l'identificazione di eventuali inadempienze; inoltre, l'azienda potrà decidere anche in seguito di adeguare le misure implementate per aderire a uno o più standard.

La figura Fig. 7.1, basata sul diagramma proposto in Parmar e Miles, «Cyber Security Frameworks (CSFs): An Assessment Between the NIST CSF v2.0 and EU Standards»,

riassume in un diagramma di flusso il processo di implementazione della direttiva NIS2 senza l'ausilio di framework.

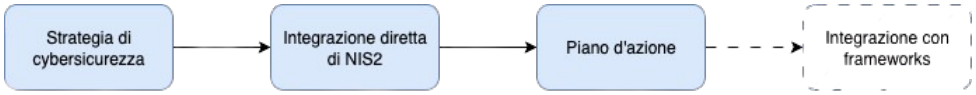


Figura 7.1: Flusso di implementazione NIS2 senza l'utilizzo di framework.

Tuttavia, è importante notare che questo è un processo particolarmente complesso e oneroso, soprattutto per le imprese che non hanno un *know-how* interno in merito ai rischi informatici e necessitano quindi di assumere figure esperte e costruire un proprio sistema senza una base preesistente. In questo contesto, adottare lo standard ISO 27001 o il framework NIST CSF 2.0 può rappresentare un'opzione valida, in quanto:

- rende il processo di adeguamento più rapido, in particolare nella parte iniziale, per poi portare a una *gap analysis* rispetto agli obblighi NIS2;
- favorisce lo sviluppo del framework di cybersicurezza interno all'azienda, basato su pratiche consolidate nelle altre organizzazioni.

La figura Fig. 7.2, basata sul diagramma proposto in Parmar e Miles, «Cyber Security Frameworks (CSFs): An Assessment Between the NIST CSF v2.0 and EU Standards», mostra come un'azienda può raggiungere l'adempimento di NIS2 tramite l'utilizzo degli standard citati, integrandoli nella propria strategia di cybersicurezza e adottando misure correttive per gli obblighi normativi non coperti.



Figura 7.2: Flusso di implementazione NIS2 con l'utilizzo di framework.

In sostanza, l'adozione diretta della direttiva NIS2, piuttosto che la realizzazione di un framework iniziale basato su standard internazionali largamente diffusi, dipende principalmente dalla maturità dei processi di gestione del rischio informatico in essere.

Aziende che dispongono di meccanismi di sicurezza consolidati e che, con ogni probabilità, già adottano ISO o NIST troveranno più naturale condurre un'analisi che attesti le differenze tra il proprio profilo e quello delineato dalla Direttiva NIS2, realizzando quindi investimenti mirati nelle aree individuate come critiche e rinforzando quanto già realizzato.

Al contrario, le organizzazioni che devono costruire la propria gestione della cybersecurity devono valutare, in base alle proprie risorse, se risulti più conveniente realizzarla direttamente sulla base del materiale normativo o se sia preferibile una fase di transizione intermedia che coinvolga l'adozione di uno standard di sicurezza già consolidato, per poi colmare gli inadempimenti.

7.3 Ruolo del CISO nell'adempimento della Direttiva NIS2

7.3.1 Evoluzione della figura del CISO

La figura del *Chief Information Security Officer* in azienda è impegnata principalmente su cinque fronti:

1. **Governance e gestione del rischio**
2. **Gestione della security by design**
3. **Gestione delle operations**
4. **Gestione dell'innovazione**
5. **Training e awareness**

Il CISO ricopre quindi un ruolo estremamente trasversale rispetto a tutte le funzioni aziendali e le sue mansioni sono profondamente cambiate nel recente periodo, in seguito all'introduzione delle moderne tecnologie e ai tentativi del legislatore di regolarne l'utilizzo per tutelare le organizzazioni e i consumatori. Il CISO è passato quindi da svolgere compiti di carattere prettamente tecnico alla necessità di integrare nel proprio profilo competenze di leadership e di gestione del rischio, coordinando le proprie azioni con il piano di business aziendale.

In questo contesto si colloca la necessità di assicurare la conformità alla Direttiva NIS2, con un impatto diretto su tutto il team di cybersecurity aziendale. Sebbene non vi sia un aumento delle responsabilità dirette del CISO, egli si trova a dover interagire frequentemente con gli organi di gestione, per adempiere agli obblighi formativi e informativi, e con i referenti delle altre funzioni, per individuare e gestire eventuali vulnerabilità.

7.3.2 Responsabilità e gestione del rischio

La Direttiva NIS2 sancisce la responsabilità diretta degli organi di gestione in materia di sicurezza informatica aziendale, mentre figure tecniche come il CISO non sono imputabili in caso di inadempimenti normativi e non possono essere oggetto di deleghe da parte del CdA su queste tematiche. In materia NIS2, il CISO si occupa di individuare le potenziali vulnerabilità, valutare i rischi in relazione al risk framework aziendale, gestirli in cooperazione con il rispettivo risk owner e sovrintendere l'implementazione della formazione, delle policy e delle misure di sicurezza informatica necessarie per la conformità agli obblighi normativi.

Pur essendo vero che NIS2 non introduce nessuna nuova responsabilità, la direttiva implica per il CISO nuovi obblighi sul piano informativo e relazionale: è necessario informare periodicamente il CdA sul profilo di rischio dell'azienda in materia di sicurezza informatica, dialogare con i responsabili delle funzioni aziendali per individuare e gestire le fonti di potenziali attacchi e strutturare un piano di formazione adeguato per ogni livello della gerarchia organizzativa. La sicurezza rappresenta quindi un tema non solo tecnico, ma soprattutto strategico e di governance organizzativa, richiedendo il coinvolgimento attivo del team di cybersicurezza nella definizione della strategia delle varie aree di business e nel dialogo periodico con il CdA e il top management.

In quest'ottica, gran parte del lavoro svolto dal CISO oggi riguarda il *risk management*: il compito principale dell'area di cybersecurity rimane l'individuazione delle vulnerabilità e la gestione dei rischi correlati. In questo processo, è necessario valutare le potenziali fonti di minacce in relazione al risk framework dell'organizzazione e al livello di rischio considerato accettabile dal legislatore, collaborando con il rispettivo *risk owner* per trattare o accettare i rischi non eliminabili direttamente.

7.4 Considerazioni generali e visione prospettica

7.4.1 Impatto futuro di NIS2

La Direttiva NIS2, soprattutto a causa del grande numero di soggetti che coinvolge, sta avendo un impatto su larghissima scala, coinvolgendo organizzazioni profondamente diverse per *core business* e dimensioni. Gli effetti di tale normativa sono ancor più evidenti

per le realtà più piccole e i settori non precedentemente regolamentati, i quali vedranno un crescente aumento degli investimenti in sistemi di sicurezza.

Ciò è certamente un fattore positivo, che si allinea con l'obiettivo del legislatore di prioritizzare la sicurezza informatica e diffondere pratiche, controlli e principi comuni in ogni campo. In questo modo, le aziende sono costrette a trattare la cybersicurezza come un tema centrale nella propria strategia, mentre il cospicuo aumento degli investimenti nei sistemi di sicurezza può, almeno sulla carta, favorirne la continua evoluzione.

Come detto, questa normativa ha anche implicazioni negative, richiedendo ingenti risorse per l'implementazione di meccanismi che soddisfino i requisiti richiesti. Tuttavia, ciò appare giustificato se osservato nell'ottica di garantire la sicurezza della società intera: la vera innovazione introdotta dalla Direttiva NIS2 risiede nel riconoscimento della sicurezza informatica come responsabilità collettiva, che coinvolge l'intera collettività, dalle imprese, chiamate a implementare adeguate misure di protezione, fino ai cittadini, sempre più esposti alle conseguenze degli attacchi digitali.

7.4.2 Intelligenza artificiale e sicurezza informatica

L'intelligenza artificiale è un elemento di trasformazione profonda per la società moderna, e il suo ruolo nella sicurezza informatica è una questione aperta e in continua evoluzione.

Come evidenziato dai report ENISA e Clusit e rimarcato anche dai CISO intervistati, l'intelligenza artificiale non ha ancora rivoluzionato il campo delle minacce cyber, ma è ragionevole ritenere che sia questione di tempo prima che ciò accada. Nell'ultimo periodo, infatti, l'AI è stata largamente impiegata negli attacchi informatici, soprattutto nelle aree del phishing e del social engineering, generando un notevole aumento del volume degli attacchi, ma non apportando alcun miglioramento qualitativo considerevole. Dunque, i cybercriminali riconoscono l'importanza dell'AI per i loro obiettivi, ma quanto osservato porta a ritenere che ancora oggi le tecnologie non siano sufficientemente sviluppate per poter attaccare in maniera completamente autonoma sistemi di difesa complessi.

Analogamente, l'intelligenza di carattere difensivo è un tema fonte di grande discussione: molte aziende intendono puntare sull'AI per costruire i propri sistemi difensivi del futuro, ma sono pochi gli esempi in cui ciò avviene realmente, mentre sono più i casi in cui il termine AI viene utilizzato impropriamente in relazione ai sistemi di cybersicurezza. Investire in queste soluzioni è particolarmente oneroso e richiede risorse che non

sono appannaggio della maggior parte delle realtà organizzative; tuttavia, è necessario che i leader di settore continuino a promuoverne lo sviluppo per poter ottenere, quanto prima, sistemi solidi ed efficaci che possano rivoluzionare concretamente il mondo della sicurezza e contrastare il crescente impiego di intelligenza artificiale offensiva da parte dei cybercriminali.

Bibliografia

Adamos Konstantinos, Fabio Di Franco, Sozon Leventopoulos e ENISA. *Cybersecurity Roles and Skills for NIS2 Essential and Important Entities: Mapping NIS2 obligations to ECSF*. Rapp. tecn. European Union Agency for Cybersecurity (ENISA), 2025.

Agenzia per la Cybersicurezza Nazionale. *Allegato 1 – Misure di sicurezza di base per i soggetti importanti (alla Determinazione ACN n. 164179/2025)*.

Agenzia per la Cybersicurezza Nazionale. *Allegato 2 – Misure di sicurezza di base per i soggetti essenziali (alla Determinazione ACN n. 164179/2025)*.

Agenzia per la Cybersicurezza Nazionale. *Determinazione del Direttore Generale dell'Agenzia per la cybersicurezza nazionale n. 164179/2025: modalità e specifiche di base per l'adempimento agli obblighi di cui agli artt. 23, 24, 25, 29 e 32 del d.lgs. 138/2024*.

Besanko David, David Dranove, Mark Shanley e Scott Schaefer. *Economia dell'industria e strategie d'impresa*. A cura di Andrea Enrietti, Elena Ottoz e Paolo P. Patrucco. 2ª ed. ISEDI, 2013.

Clusit. *Rapporto Clusit sulla Cybersecurity in Italia e nel mondo*. Rapp. tecn. Clusit – Associazione Italiana per la Sicurezza Informatica, 2025.

Commissione Europea. *Regolamento di esecuzione (UE) 2024/2690 della Commissione del 17 ottobre 2024 che stabilisce norme per l'applicazione della direttiva (UE) 2022/2555*. Gazzetta ufficiale dell'Unione europea, 17 ottobre 2024.

ECSO. *ECSO White Paper — NIS2 Implementation: Challenges & Priorities*. Rapp. tecn. Working Group Cyber Threat Management. European Cyber Security Organisation (ECSO), 2025.

ENISA. *Enisa Threat Landscape 2024*. Rapp. tecn. Da luglio 2023 a giugno 2024. European Union Agency for Cybersecurity (ENISA), 2024.

ISO/IEC. *ISO/IEC 27001:2022(E) – Information security, cybersecurity and privacy protection — Information security management systems — Requirements*. Rapp. tecn.

Third edition. International Organization for Standardization (ISO) e International Electrotechnical Commission (IEC), 2022.

Kouns Barry S. e Jake Kouns. *The CISO Perspective: Understand the importance of the CISO in the cyber threat landscape*. IT Governance Publishing, 2023.

McIntosh Timothy R., Teo Susnjak, Tong Liu, Paul Watters, Dan Xu, Dongwei Liu, Raza Nowrozy e Malka N. Halgamuge. *From COBIT to ISO 42001: Evaluating cybersecurity frameworks for opportunities, risks, and regulatory compliance in commercializing large language models*. In: *Computers & Security* 144 (2024).

Mitnick Kevin D. e William L. Simon. *L'arte dell'inganno. I consigli del più famoso hacker del mondo per ingannare chiunque e proteggersi da chiunque*. Feltrinelli, 2003.

Moulinos Konstantinos, Marianthi Theocharidou e ENISA. *Implementing Guidance on Commission Implementing Regulation (EU) 2024/2690 of 17.10.2024 laying down rules for the application of Directive (EU) 2022/2555 as regards technical and methodological requirements of cybersecurity risk-management measures*. Rapp. tecn. Draft for Public Consultation. European Union Agency for Cybersecurity (ENISA), 2024.

NIST. *The NIST Cybersecurity Framework (CSF) 2.0*. Rapp. tecn. National Institute of Standards e Technology (NIST), 2024.

Parmar Manisha e Andy Miles. *Cyber Security Frameworks (CSFs): An Assessment Between the NIST CSF v2.0 and EU Standards*. In: (2024).

Repubblica Italiana. *Decreto Legislativo 4 settembre 2024, n. 138. Recepimento della Direttiva (UE) 2022/2555*. Gazzetta Ufficiale n. 230 del 1 ottobre 2024.

Teichmann Fabian. *Cybersecurity of critical infrastructure in Europe: the NIS2 directive in focus*. In: *International Cybersecurity Law Review* 6 (2025).

Toussaint Marion, Sylvère Krima e Hervé Panetto. *Industry 4.0 data security: A cybersecurity frameworks review*. In: *Journal of Industrial Information Integration* 39 (2024).

UNI. *UNI/CT 001/GL 03 "Sistemi di gestione: HS, gestione del rischio e altri aspetti applicativi"*. Struttura Armonizzata per le Norme sui Sistemi di Gestione e Guida per l'Uso. 2023.

UNI. *UNI/PdR 174:2025*. Sistema di gestione per la cybersicurezza e la sicurezza delle informazioni armonizzato alla norma UNI CEI EN ISO/IEC 27001 e al Framework NIST CSF 2.0. 2025.

Unione Europea. *Direttiva (UE) 2016/1148 del Parlamento Europeo e del Consiglio del 6 luglio 2016 recante misure per un livello comune elevato di sicurezza delle reti e dei sistemi informativi nell'Unione (NIS)*. Gazzetta ufficiale dell'Unione europea, 19 luglio 2016.

Unione Europea. *Direttiva (UE) 2022/2555 del Parlamento Europeo e del Consiglio del 14 dicembre 2022 relativa a misure per un livello comune elevato di cibersicurezza nell'Unione (NIS 2)*. Gazzetta ufficiale dell'Unione europea, 27 dicembre 2022.

Vandezande Niels. *Cybersecurity in the EU: How the NIS2-directive stacks up against its predecessor*. In: *Computer Law & Security Review* 52 (2024).

Watkins Steve G. *ISO/IEC 27001:2022: An introduction to information security and the SGSI standard*. IT Governance Publishing, 2022.

Sitografia

Agenzia per la Cybersicurezza Nazionale. *Ambito di applicazione NIS2*. URL: https://www.acn.gov.it/portale/nis/ambito#application (visitato il giorno 03/10/2025).

Deloitte. *The NIS2 Directive*. 2023. URL: https://www.deloitte.com/nl/en/services/risk-advisory/perspectives/the-nis2-directive.html (visitato il giorno 17/09/2025).

Interviste

Matteo Herin. *Intervista al CISO & Head of Cybersecurity AI Competence Center di Carrefour Italia, Matteo Herin*. Intervista condotta dall'autore in data 10/09/2025. Set. 2025.

Michele Rivieri. *Intervista al CISO di Prometeia, Michele Rivieri*. Intervista condotta dall'autore in data 17/09/2025. Set. 2025.

Ringraziamenti

Desidero esprimere la mia sincera gratitudine a Francesco Zazza, Mattia D'Ambrosio, Matteo Herin, Piero Randazzo e Michele Rivieri per la disponibilità e il prezioso supporto offerto nella ricerca dedicata alla figura del CISO. Il loro contributo ha arricchito significativamente questo lavoro, rendendolo più concreto e vicino alla realtà professionale.

Un sentito ringraziamento al professor Edoardo Mollona e alla dottoressa Anastasio per la guida attenta, la competenza e la fiducia dimostrate durante il percorso di redazione della tesi. La possibilità di approfondire temi che sento affini alle mie aspirazioni future ha rappredentato per me un'occasione di crescita personale e professionale di grande valore.

Un grazie speciale a tutti i miei amici, compagni di strada e di vita, per la loro presenza costante, il sostegno e le risate che hanno accompagnato questi anni.

Infine, il mio pensiero più profondo va alla mia famiglia, che è e rimarrà sempre il mio porto sicuro, fonte di forza, serenità e ispirazione nei momenti di gioia come in quelli di difficoltà.

Francesco Maria Fuligni